

Laboratorios Owasp top 10

Fabian Camilo Garzón Cative

Universidad de Cundinamarca

Extensión Chía

Línea de profundización III

Junio 2023

Tabla de contenidos

Introducción.....	3
Objetivos	4
Objetivo general	4
Objetivos específicos	4
A7 Fallos de identificación y autorización	5
Lab 2FA simple bypass	5
A8 Fallos de integridad de datos y software	13
Lab Modifying serialized objects.....	13
A9 Fallos de registro y monitoreo de seguridad	24
Honeydrive.....	24
A10 Server side request forgery.....	34
Lab Basic SSRF against the local server.....	34
Conclusiones	44

Introducción

El siguiente trabajo continúa con el owasp top 10, en este caso desde el A7 al A10, concluyendo de este modo el top 10 del 2021. Por ello el trabajo está dividido en cuatro partes, la primer, parte será el A7 dónde se hará un laboratorio en el cuál se vulnera un factor de doble verificación, para ello se usará Kali Linux, burpsuite y el portswigger en el navegador.

La segunda parte es un laboratorio también en portswigger dónde se hará una deserialización de una cookie para acceder a un modo de administrador y eliminar una cuenta, al igual que en el anterior laboratorio se hará uso de Kali Linux, burpsuite y el portswigger.

La tercera parte es un laboratorio donde se busca capturar un posible ataque a través de un servidor que se creará en la máquina virtual Honeydrive, luego se hará un escaneo de puertos en Kali Linux y en la interfaz del Dionaea, servidor montado en honeydrive, aparecerán los ataques. Para este laboratorio se hará uso de Kali Linux, Honeydrive, Dionaea y DionaeaFR.

Para finalizar el documento se hará un laboratorio en portswigger nuevamente para eliminar el usuario Carlos, pero para hacerlo esta vez se accede a usuario administrador desde una Api, modificándola y accediendo como administrador. El laboratorio se hace en Kali Linux con burpsuite y portswigger.

Objetivos

Objetivo general

- Culminar el proceso de estudio de las vulnerabilidades más comunes dadas en el owasp top 10 2021.

Objetivos específicos

- Preparar las máquinas virtuales y demás herramientas que se necesiten para cada uno de los laboratorios.
- Aprovechar exploits en páginas inseguras para tener acceso a datos.
- Capturar a los atacantes con un honeypot montando un servidor y de este modo evitar posibles ataques.

A7 Fallos de identificación y autorización

Lab 2FA simple bypass

Para el siguiente laboratorio se utilizará Kali Linux y el portswigger, para ver el A7 buscar en el navegador el Lab 2FA symple bypass en portswigger. A través de este laboratorio se obtendrá acceso a una cuenta sin colocar el código de seguridad que envía la página.

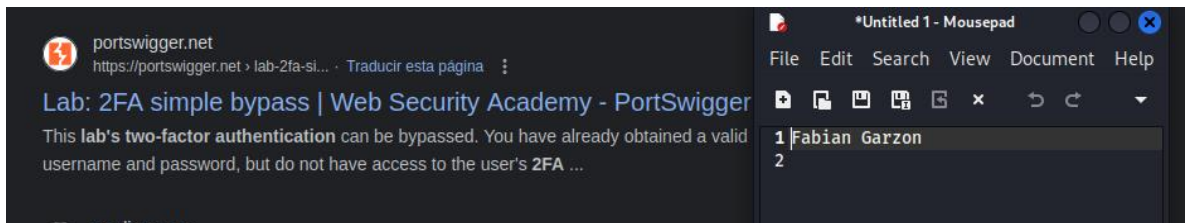


Imagen 1. Búsqueda laboratorio

Lab: 2FA simple bypass

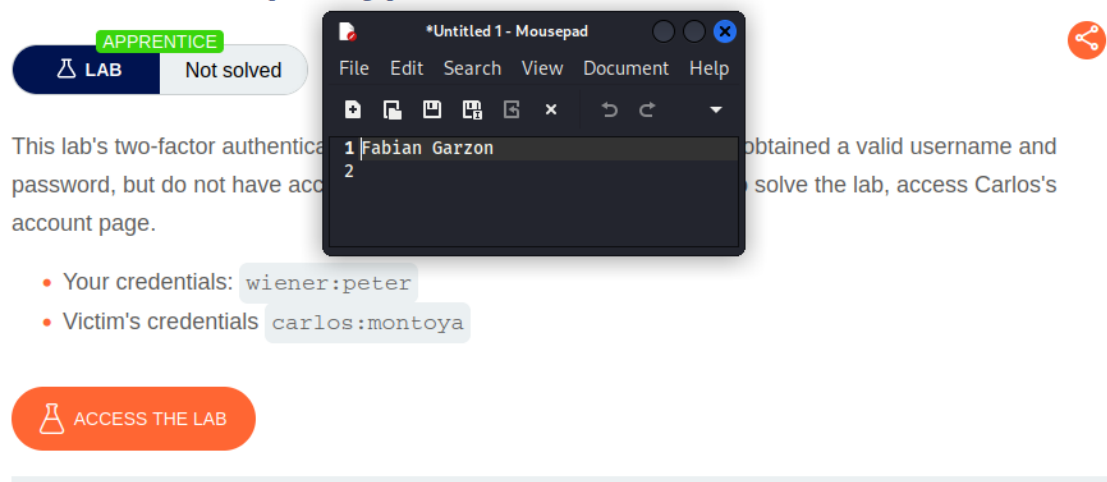


Imagen 2. Laboratorio en Portswigger

Dar clic en acces the lab para empezar el laboratorio.



Imagen 3. Página principal del laboratorio

Iniciar sesión con las credenciales que se dan en la descripción del laboratorio, que son wiener y peter.

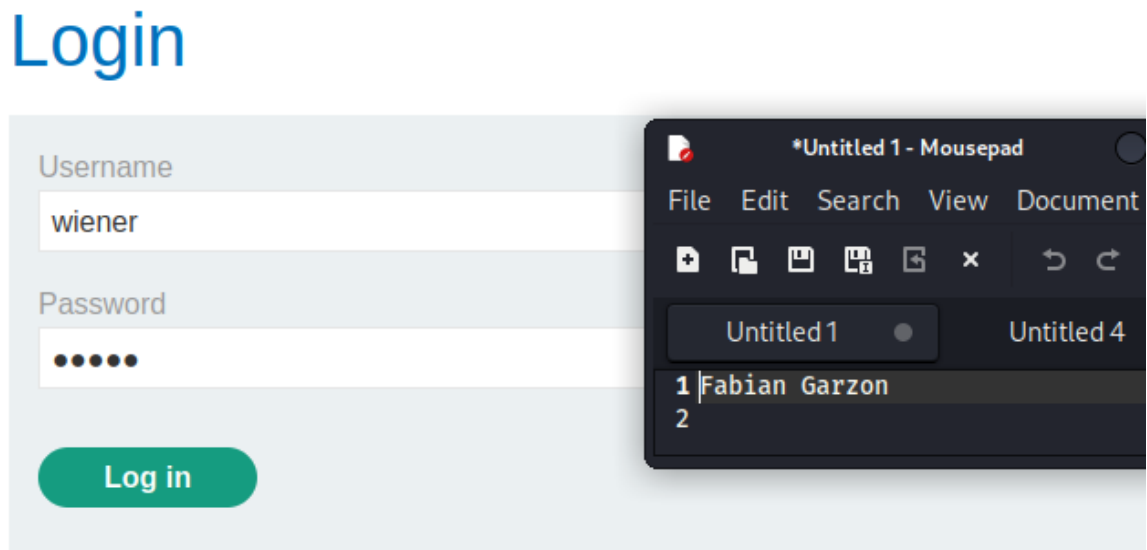


Imagen 4. Logueo con las credenciales

Al dar clic en login se va a mostrar una nueva página dónde se pide un código de seguridad de 4 dígitos.

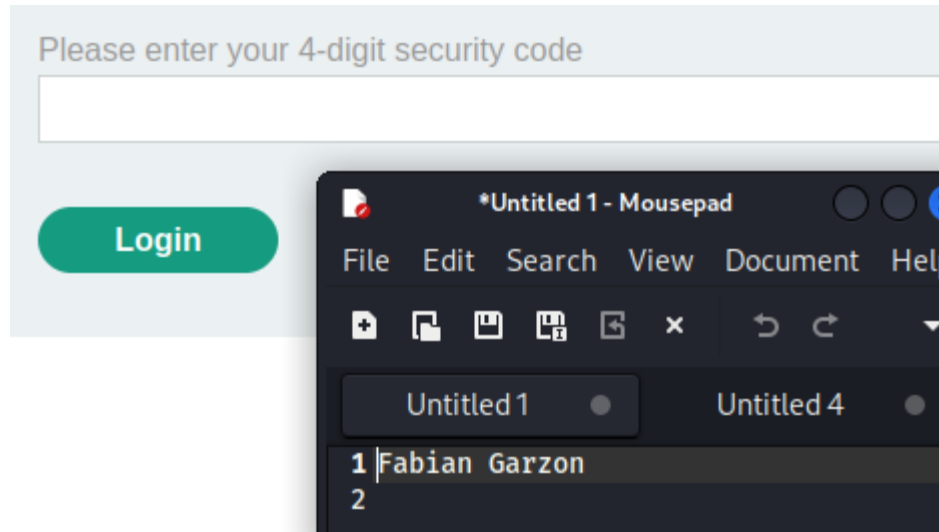


Imagen 5. Página para insertar los 4 dígitos

Entonces para saber cuál es este código dar clic en la parte superior dónde dice Email client, este es como una especie de portal de Email para este laboratorio.

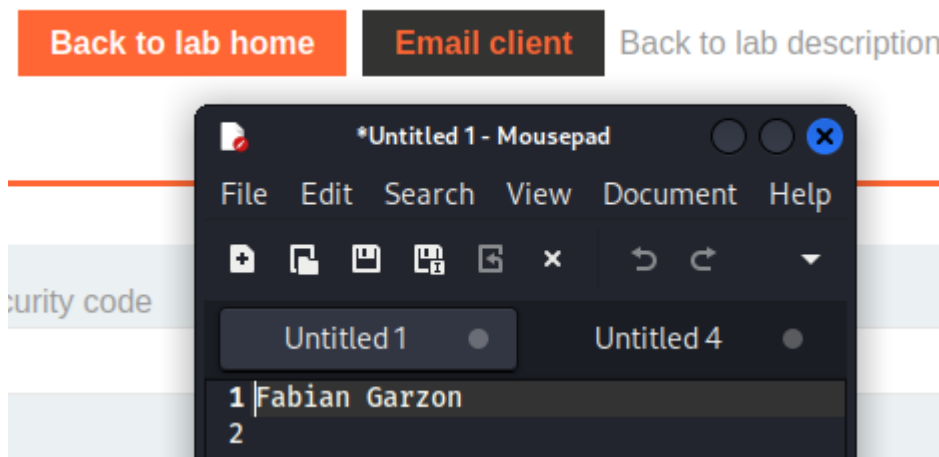


Imagen 6. Pestaña email client

Al dar clic allí se verá un correo dónde está el código para poder acceder a la cuenta.

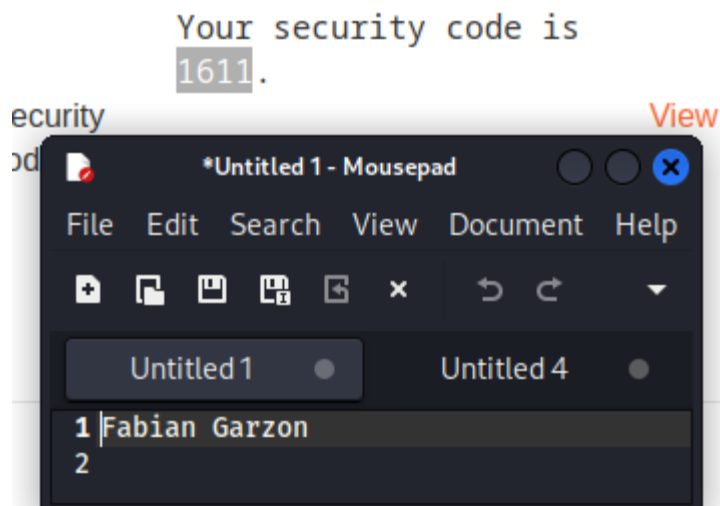


Imagen 7. Correo con el código de seguridad

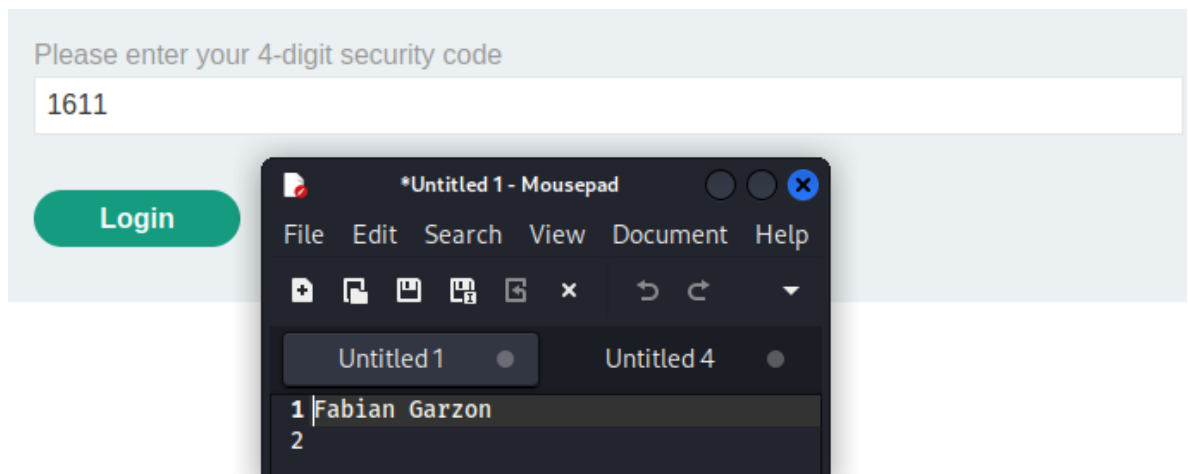


Imagen 8. Inserción del código en el campo

Al colocar el código, luego se mostrará una página dónde dice cual es el usuario y el correo que está vinculado a esa cuenta.

My Account

Your username is: wiener

Your email is: wiener@exploit-0a9000600332578e800684cf017100f5.exploit-server.net

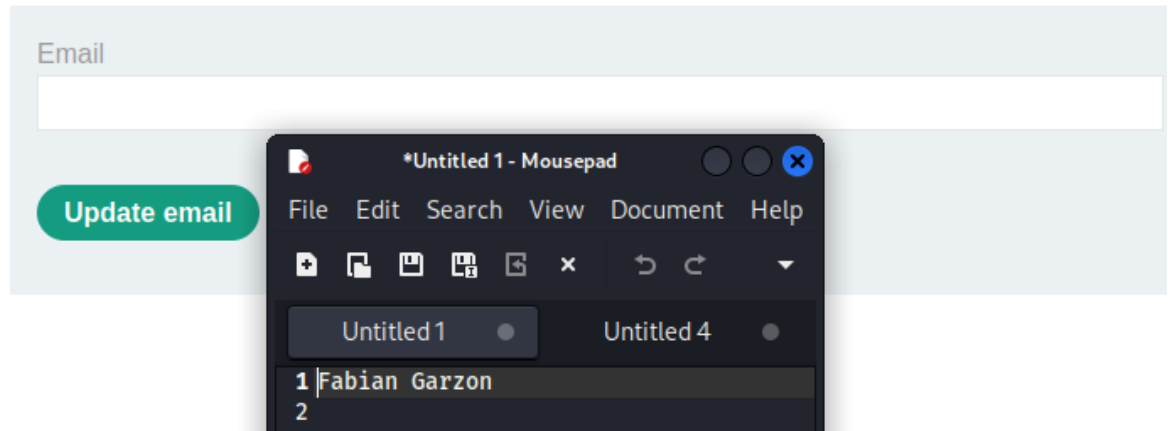


Imagen 9. Logueo exitoso

Ahora copiar la URL que está en el navegador sin cambiar de pestaña.

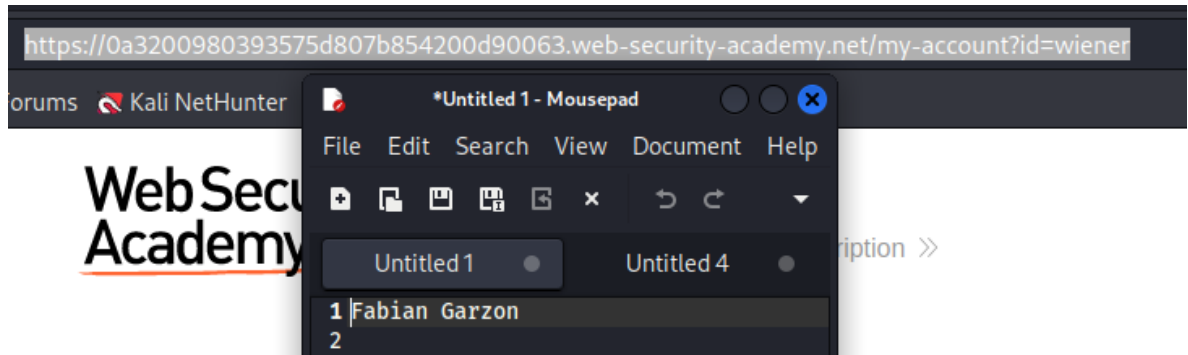


Imagen 10. Copia de la URL

Ahora cerrar sesión.

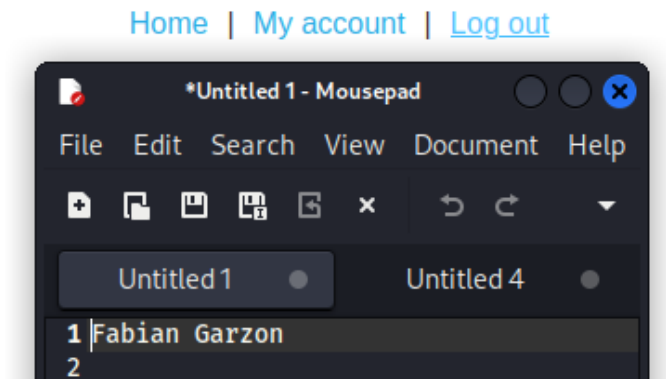


Imagen 11. Cierre de sesión

Ahora iniciar con la otra cuenta que se da en la descripción del laboratorio para hacer el mismo procedimiento. Las credenciales de la otra cuenta son carlos y montoya.

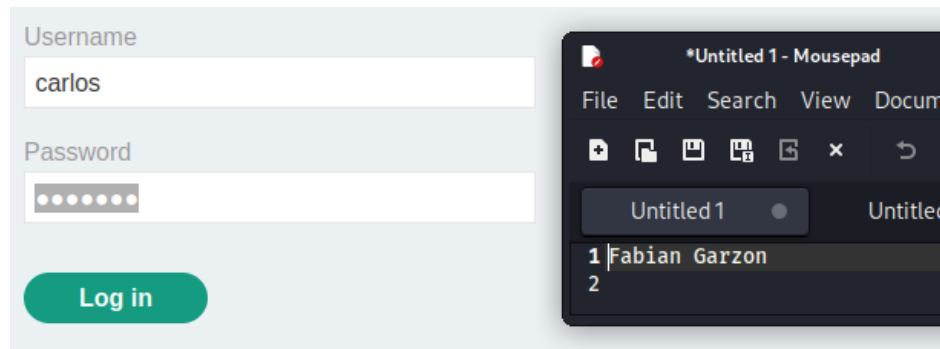


Imagen 12. Inicio de sesión con las credenciales de la otra cuenta

Como con la anterior cuenta se va a pedir un código de seguridad.

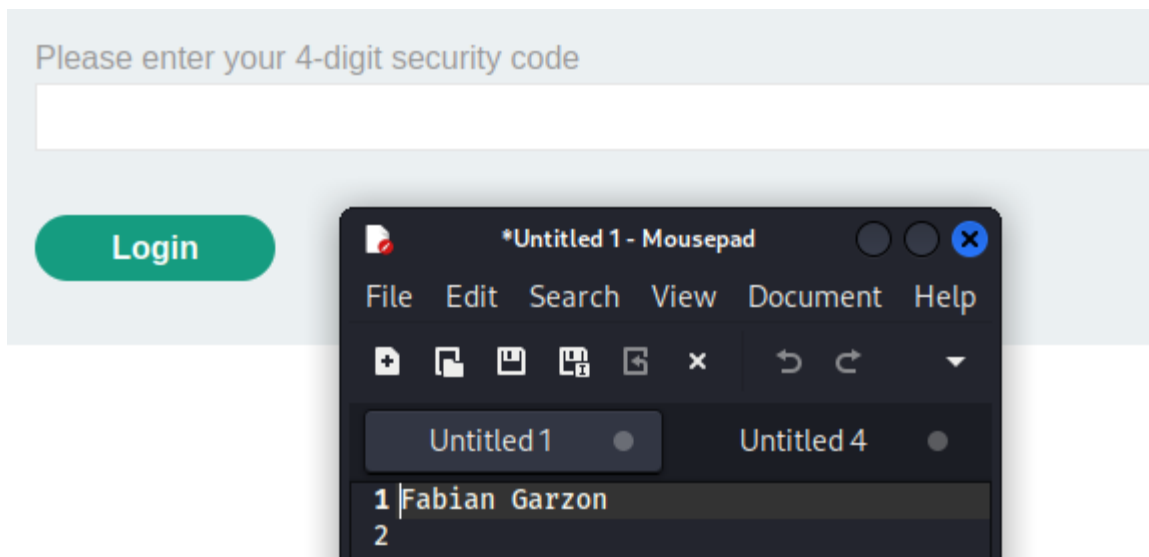


Imagen 13. Página para colocar el código de seguridad

Pero esta vez para revisar el correo y el código de seguridad, al dar clic en Email client, la página mostrará nuevamente el correo que llegó a la cuenta de Wiener y no se tendrá acceso a la cuenta Carlos.

wiener@exploit-
0a9000600332578e800684cf017100f
5.exploit-server.net

no-
reply@0a3200980393575d807b854200d
90063.web-security-academy.net

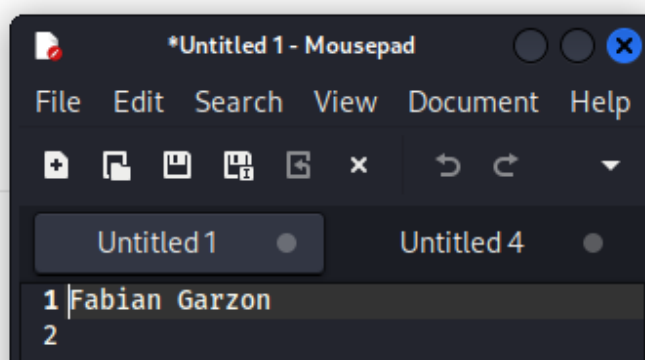


Imagen 14. Correo de Wiener

Para poder entrar a la cuenta de Carlos lo único que hay que hacer es cambiar la URL del navegador y colocar my-account y dar enter, al hacer eso automáticamente se da acceso a la cuenta y el laboratorio fue solucionado exitosamente.

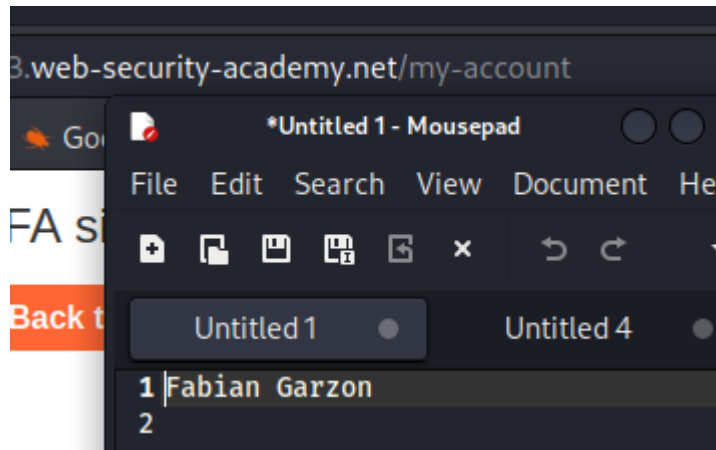


Imagen 15. Cambio de URL

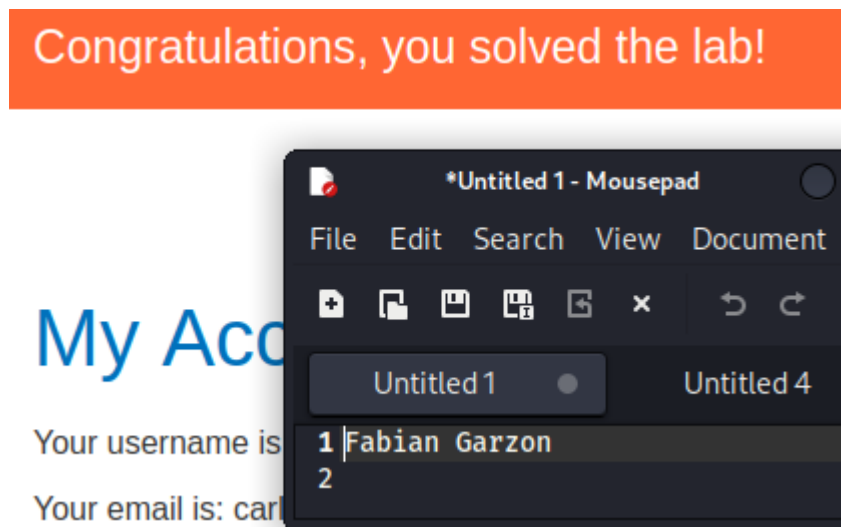


Imagen 16. Laboratorio solucionado

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

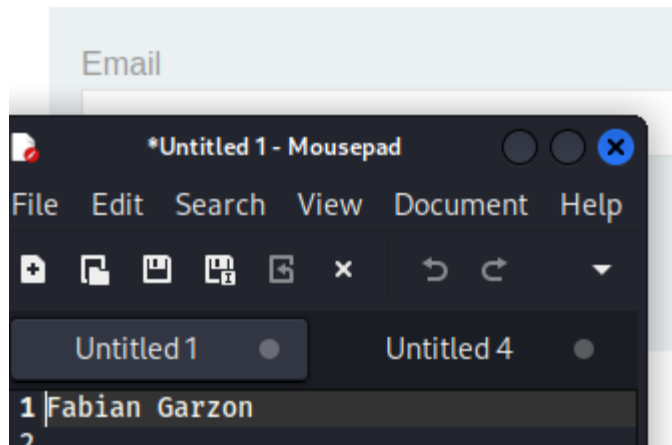


Imagen 17. Credenciales y correo de Carlos

A8 Fallos de integridad de datos y software

Lab Modifying serialized objects

Al igual que para el anterior laboratorio se usará Kali Linux y portswigger, buscar en portswigger el laboratorio modifying serialized objects. En este laboratorio se borrará una cuenta sin ser administrador, esto se logra modificando una cuenta normal a una de administrador para poder hacer este delete.

Lab: Modifying serialized objects

APPRENTICE

LAB

Not solved

This lab uses a serialization-based session mechanism and is vulnerable to privilege escalation as a result. To solve the lab, edit the serialized object in the session cookie to exploit this vulnerability and gain administrative privileges. Then, delete the user `carlos`.

You can log in to your own account using the following credentials: `wiener:peter`

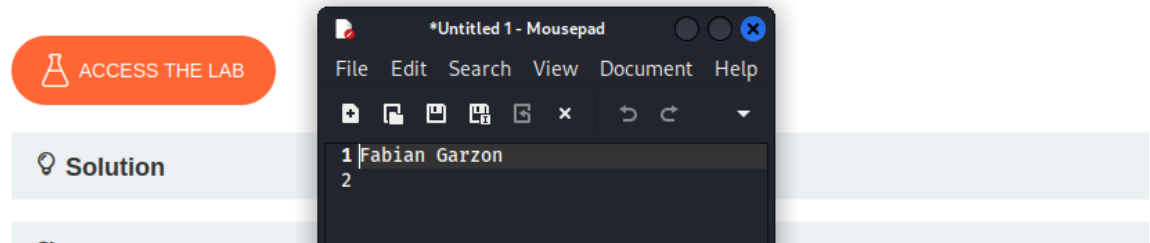


Imagen 18. Búsqueda del laboratorio

Acceder al laboratorio y entrar a My account.

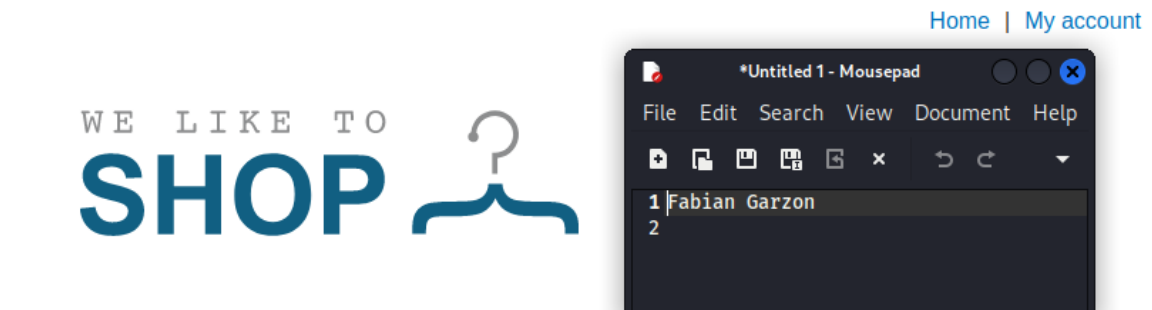


Imagen 19. Página principal del laboratorio

Ir a la configuración del navegador y activar el proxy ya que se va a utilizar el burpsuite.

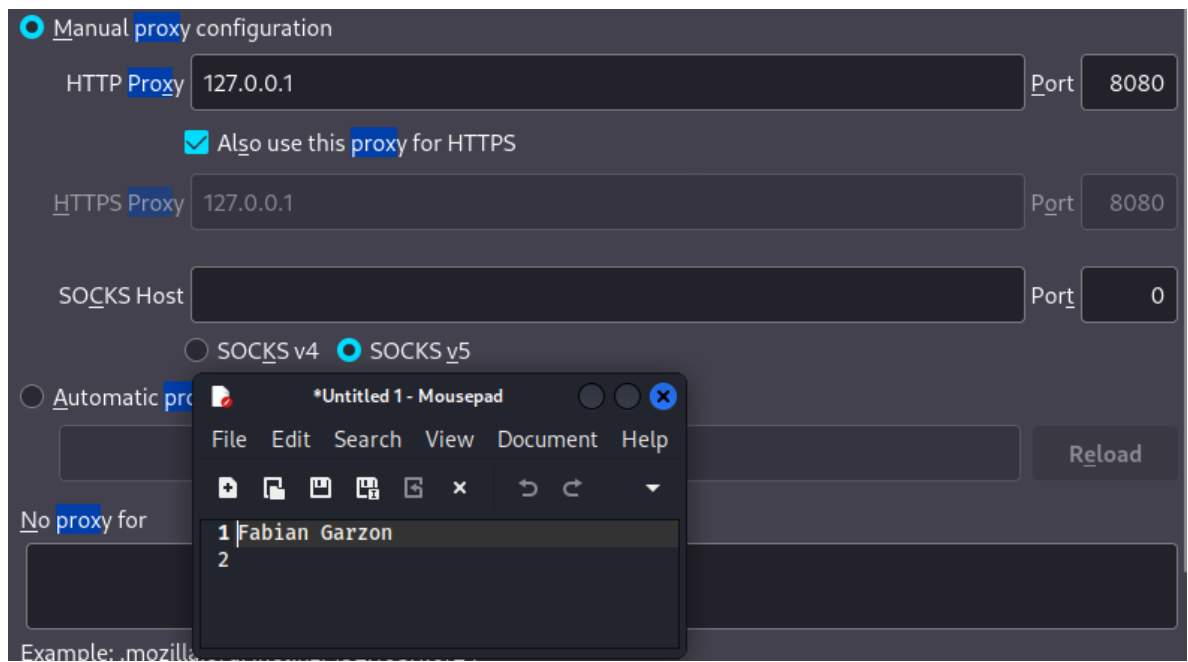


Imagen 20. Activación del proxy

Abrir el burpsuite e ir a la parte de proxy en intercept y encenderlo.

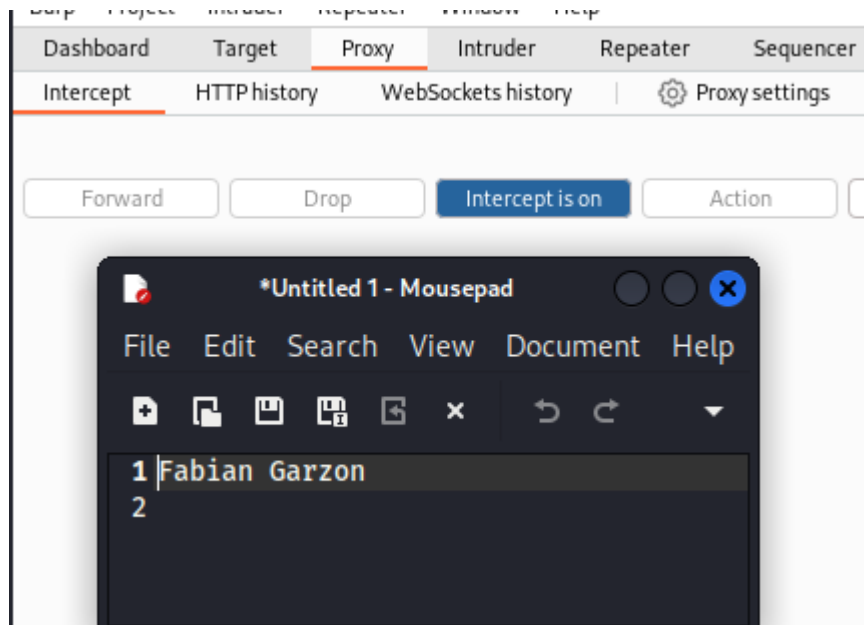


Imagen 21. Activar intercept en el proxy

En my account, loguearse con las credenciales que se dan en la descripción del laboratorio, wiener y peter.

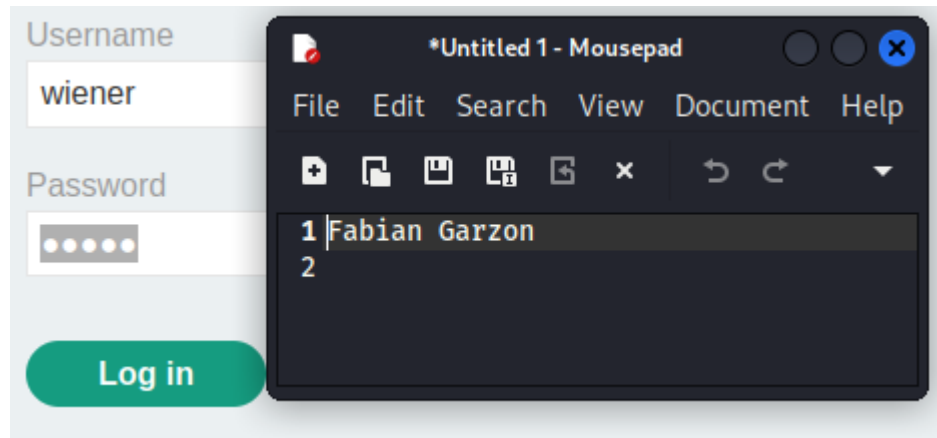


Imagen 22. Logueo con las credenciales

Al dar clic en Log in, se abrirá el burpsuite y aparecerá una ventana con lo que se capturó, al ver la cookie session, estará en blanco, entonces para que se muestre la cookie se debe dar clic en forward para que capture lo siguiente.

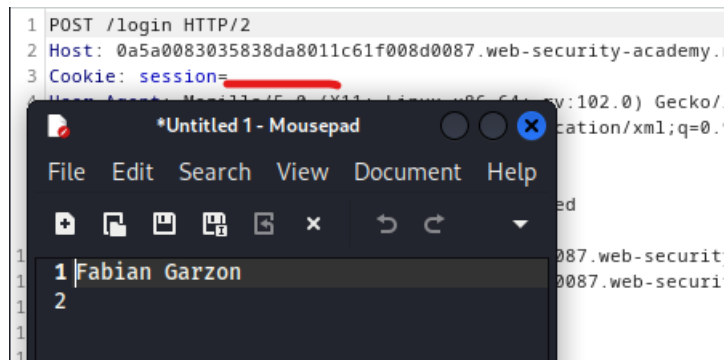


Imagen 23. Cookie session vacía

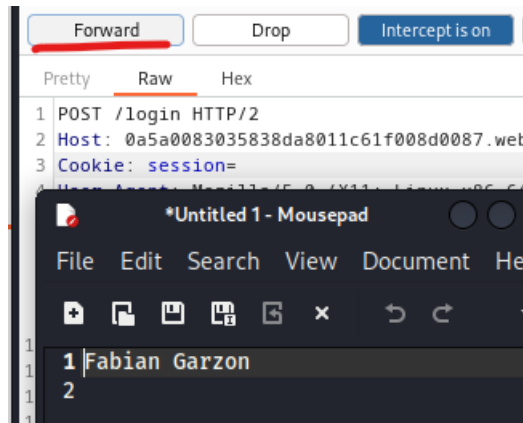


Imagen 24. Clic en forward

Al dar clic en forward, la cookie deja de estar vacía y aparecerán una serie de caracteres en color rojo.

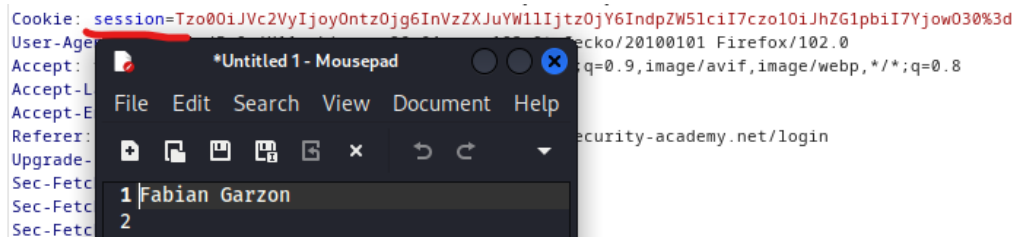


Imagen 25. Apareció la cookie session

Ahora oprimir control + R para mandar ese texto al repeater o dar clic derecho y enviar a repeater.

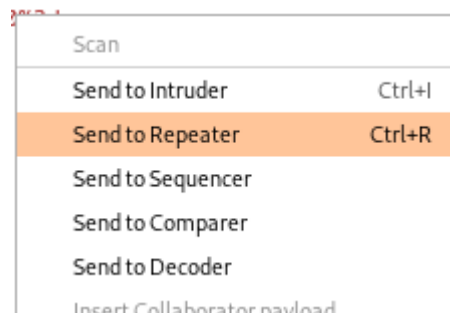


Imagen 26. Envío a repeater

Apagar el intercept en burpsuite para que deje de capturar lo que se haga más adelante.

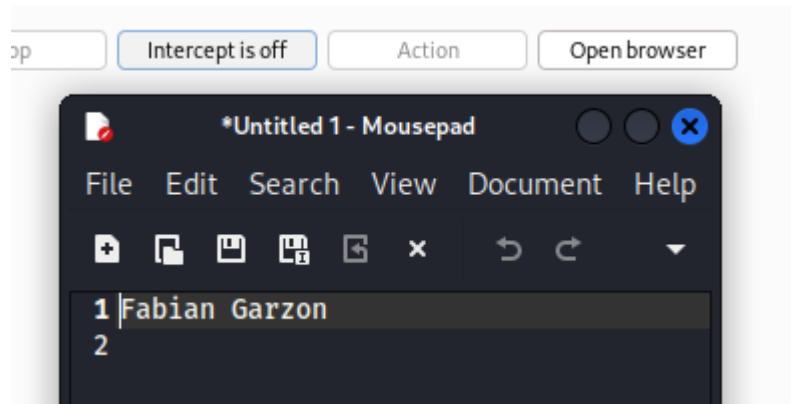


Imagen 27. Apagar intercept

En el repeater seleccionar la cookie session para decodificar esa cookie.

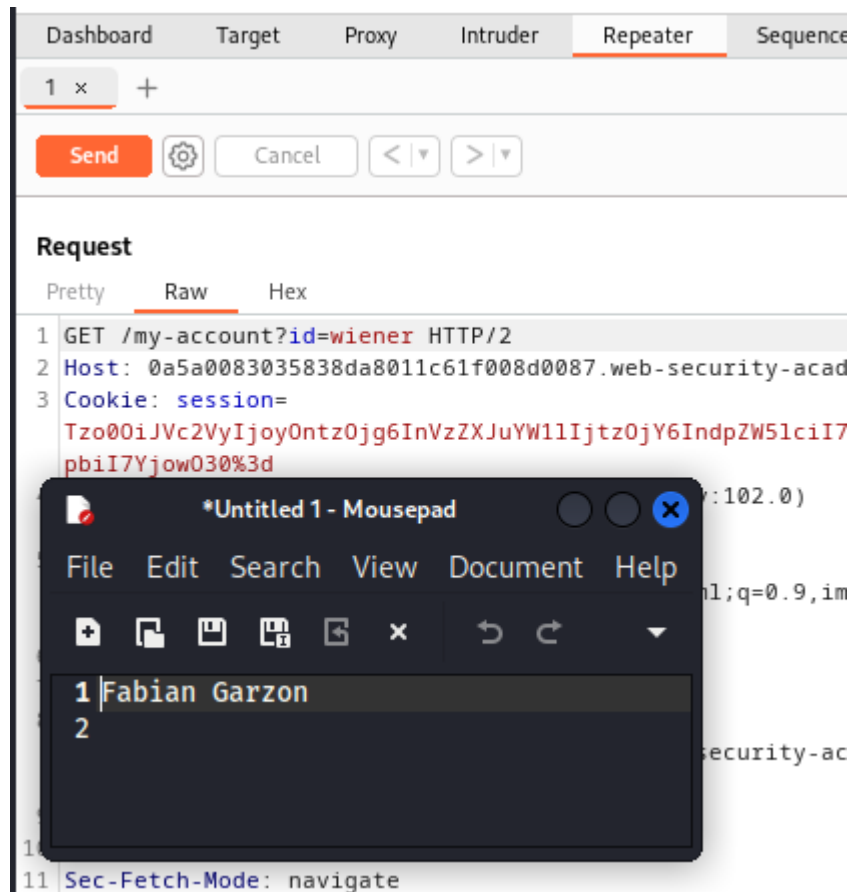


Imagen 28. Repeater con lo capturado por el intercept

Para hacer la decodificación dar clic derecho, ir a convert selection, base64 y base64 decode. Al hacer esto, en el inspector se verá la decodificación en base 64.

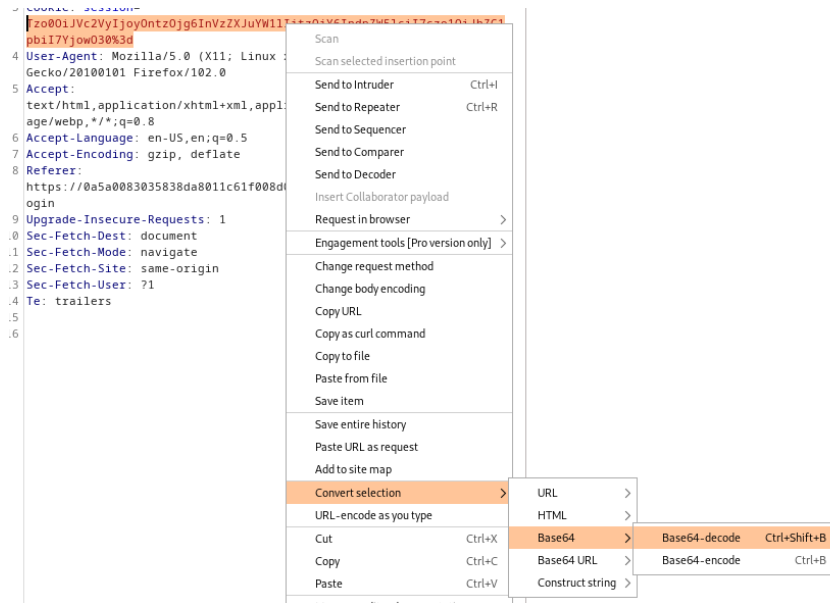


Imagen 29. Decodificar la cookie

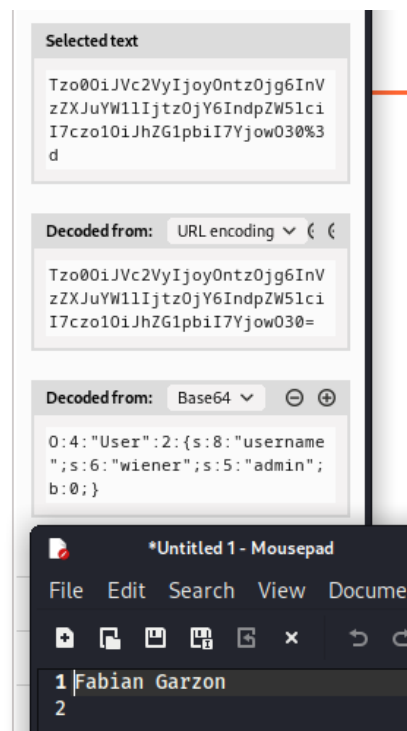


Imagen 30. Inspector con la decodificación

En la decodificación base64, aparece el nombre de usuario y en admin aparece un 0, lo cual se interpreta como que no es una cuenta de administrador, entonces cambiar ese 0 por un 1 y dar clic en apply changes.

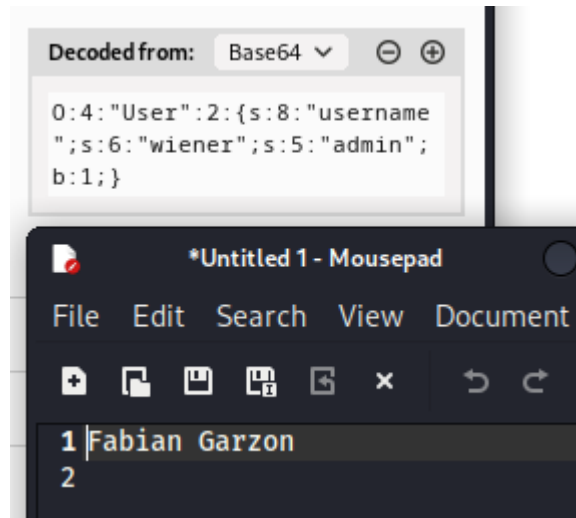


Imagen 31. Cambio del 0 por 1

Al dar clic en apply changes la cookie session cambia automáticamente y ya solo toca dar clic en send.

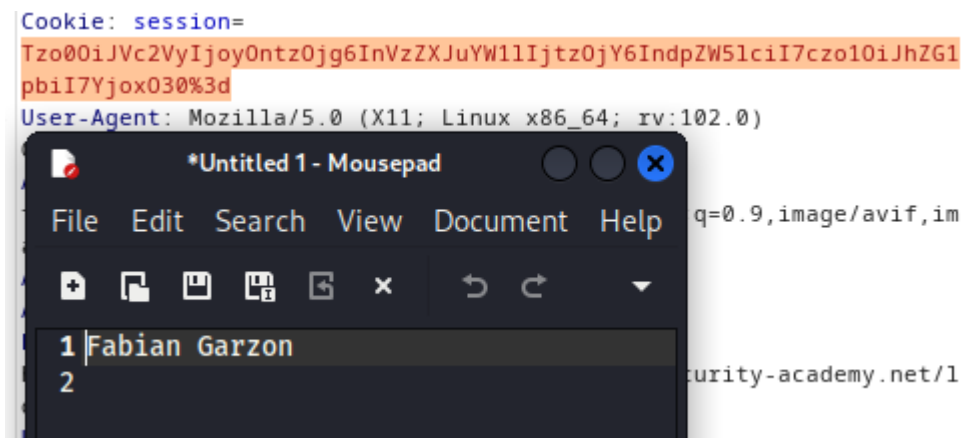


Imagen 32. Cambio de la cookie session

Al dar clic en send, en la parte de response se mostrará un código, dar clic en raw para que se vea más ordenado y buscar que diga Admin panel.

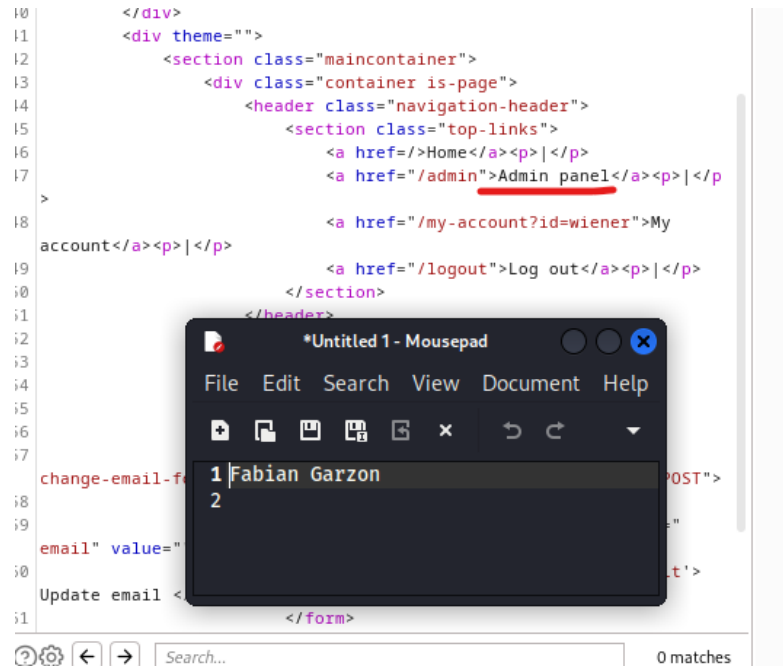


Imagen 33. Admin panel en response raw

Modificar el GET y colocar /admin y nuevamente en send.

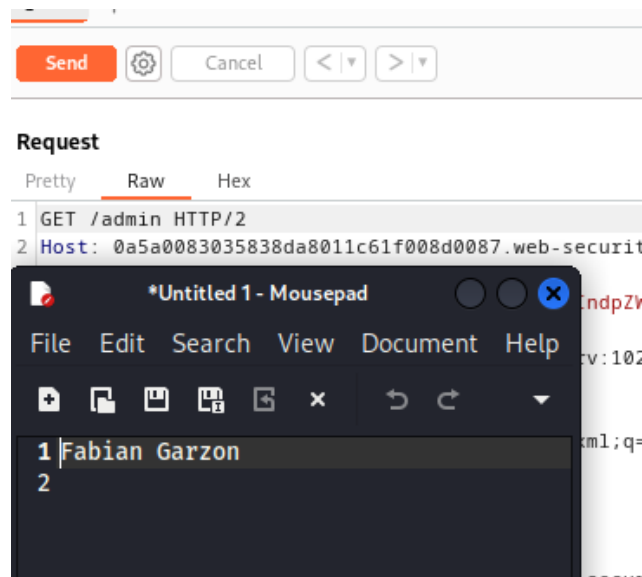


Imagen 34. Cambio del GET

Dar clic en response en render, allí se mostrarán los usuarios que hay.

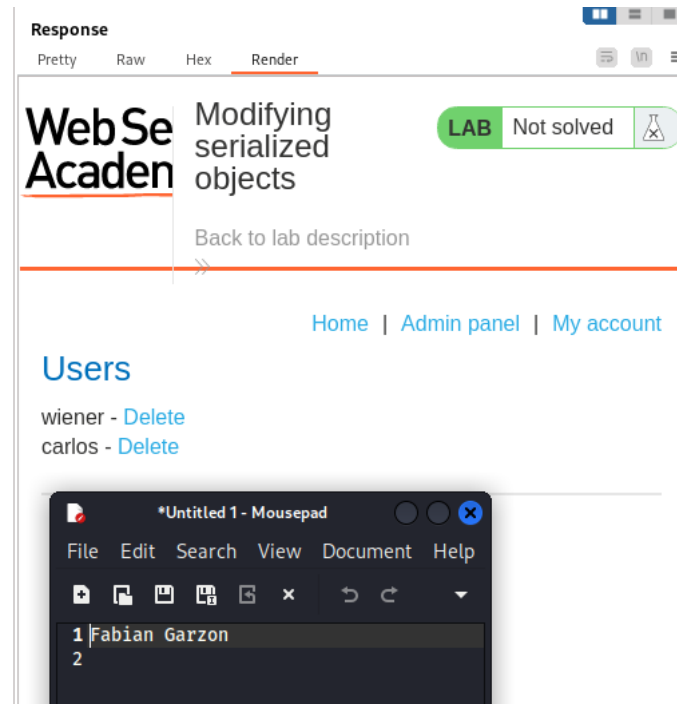


Imagen 35. Response render de los usuarios

Para poder solucionar el laboratorio se debe eliminar al usuario Carlos, entonces en el GET añadir al /admin lo siguiente /delete?username/=carlos.

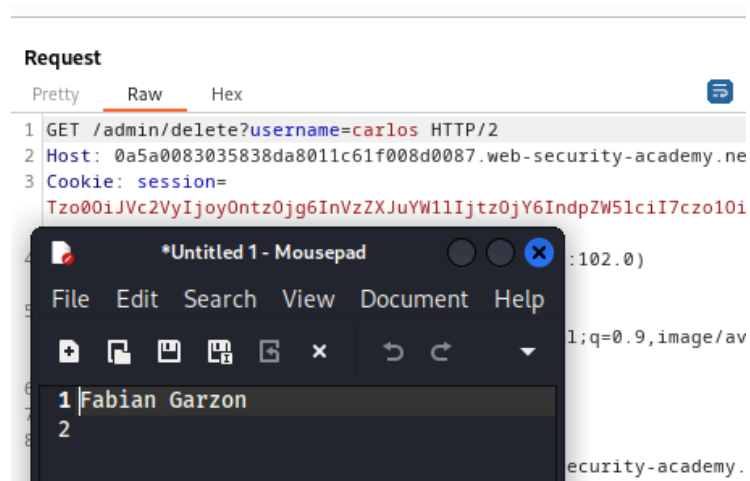


Imagen 36. Eliminar al usuario desde el GET

Al hacer esto, en el response aparecerá el siguiente mensaje y el laboratorio quedará resuelto.

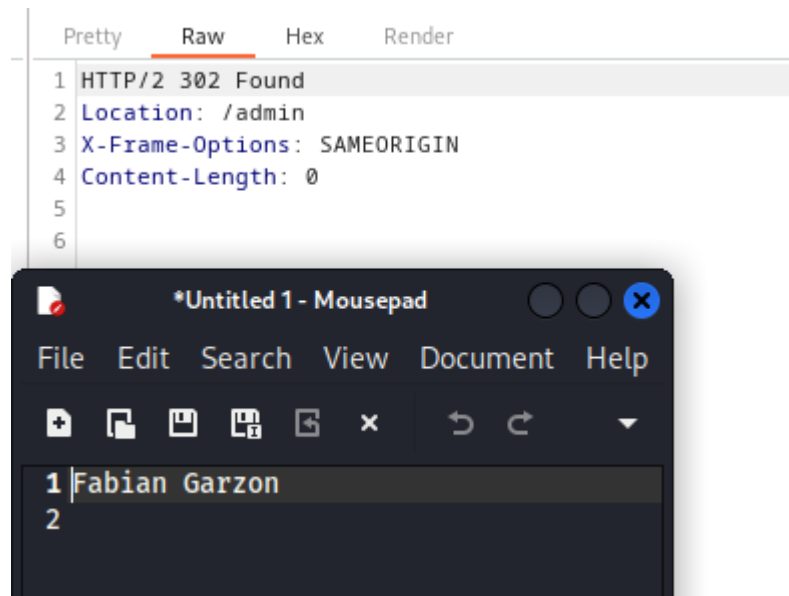


Imagen 37. Resultado en response raw

Congratulations, you solved the lab!

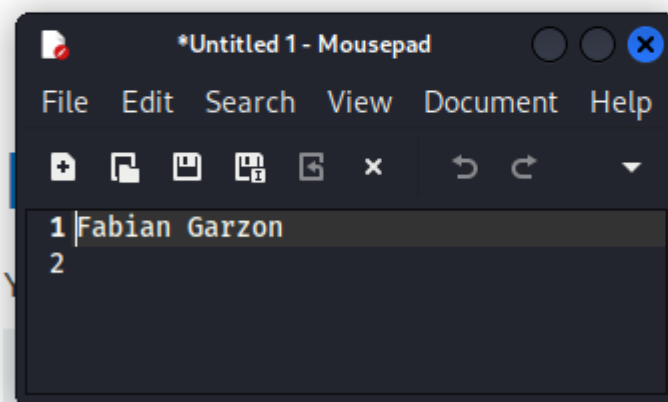


Imagen 38. Laboratorio resuelto

A9 Fallos de registro y monitoreo de seguridad

Honeydrive

En el siguiente laboratorio se hará un honeypot, esto lo que hace es capturar los posibles ataques que se le hagan a la página, para ello se hará uso de Kali Linux y la Honeydrive.

Primero ejecutar la máquina virtual honeydrive.



Imagen 39. Ejecución Honedryive

Configurar Kali Linux y Honedrive en comunicación, esto puede ser a través de adaptador puente o red nat, en este caso se hizo mediante adaptador puente.

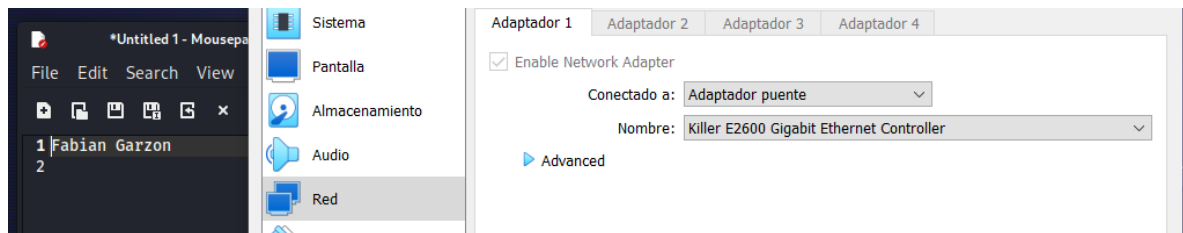


Imagen 40. Configuración adaptadores de red

Abrir una terminal en honeydrive y verificar la ip de la máquina.

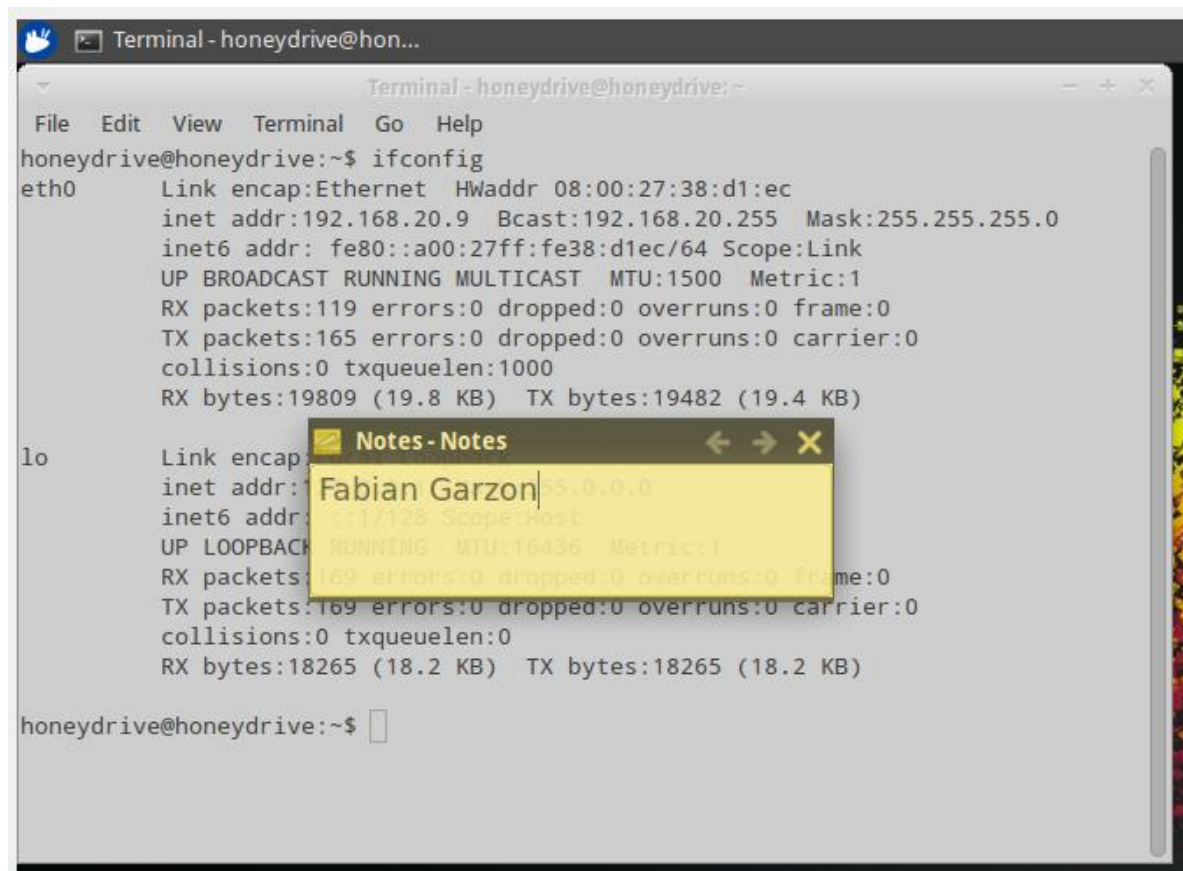


Imagen 41. Comando ifconfig para ver la ip

Abrir el documento de texto que está en el escritorio llamada README, esto para ver las opciones que da la máquina y ver su funcionamiento.

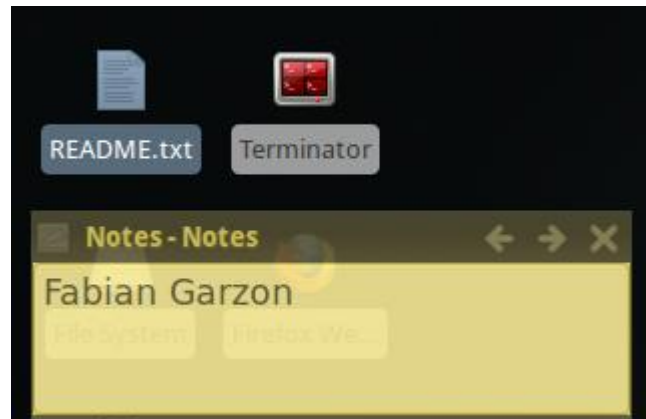


Imagen 42. Documento README

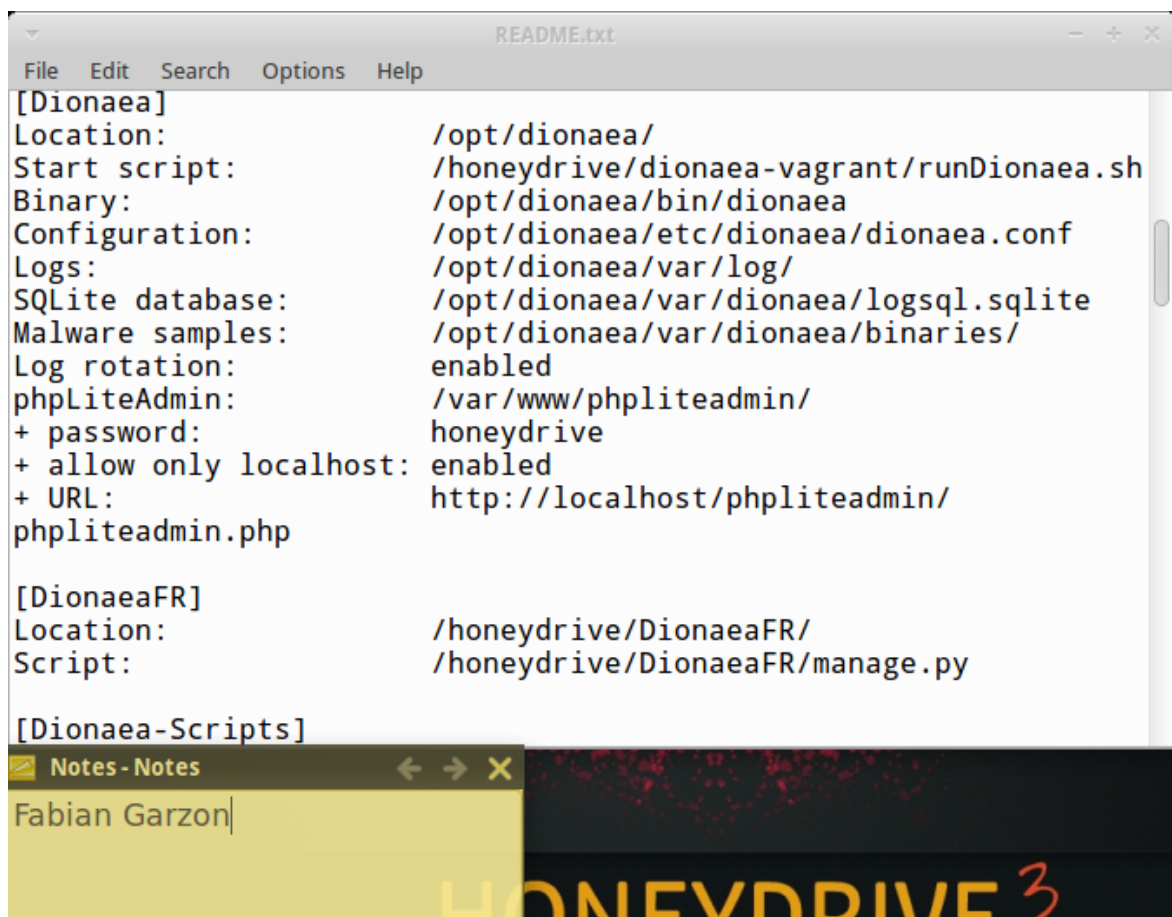


Imagen 43. Documento README abierto

En la terminal ir al directorio raíz de dionaea.

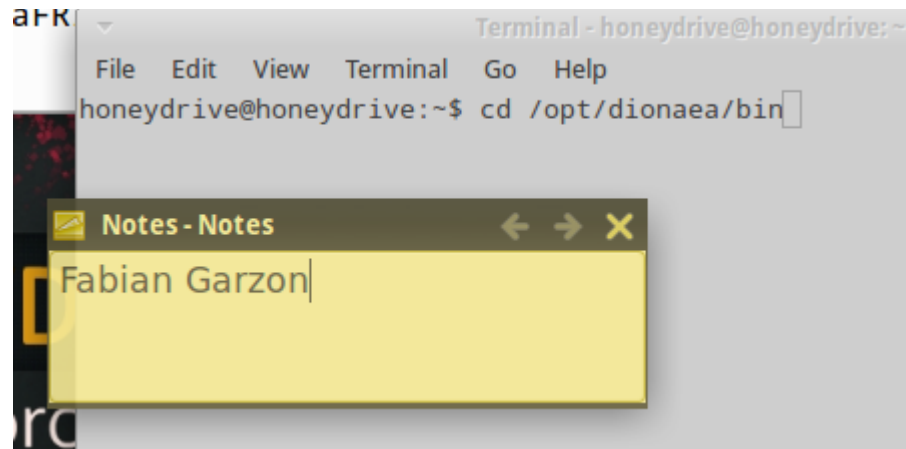


Imagen 44. Ir a carpeta raíz

Hacer un ls para ver el contenido de dicha carpeta.

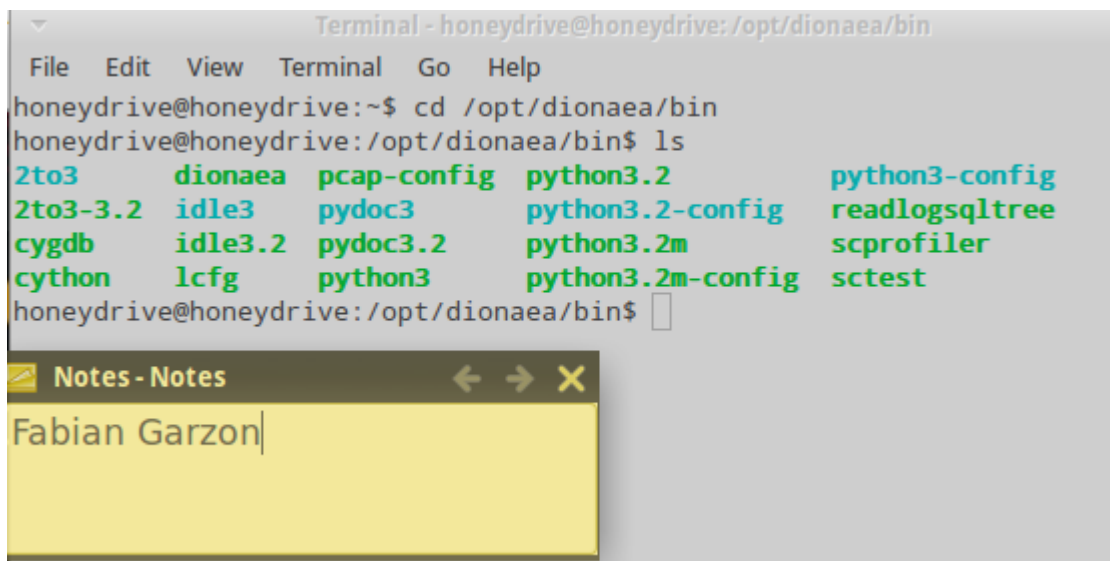


Imagen 45. Listado de la carpeta raíz dionaea

Subir los servicios del dionaea para posteriormente poderlos ejecutar en un servidor.

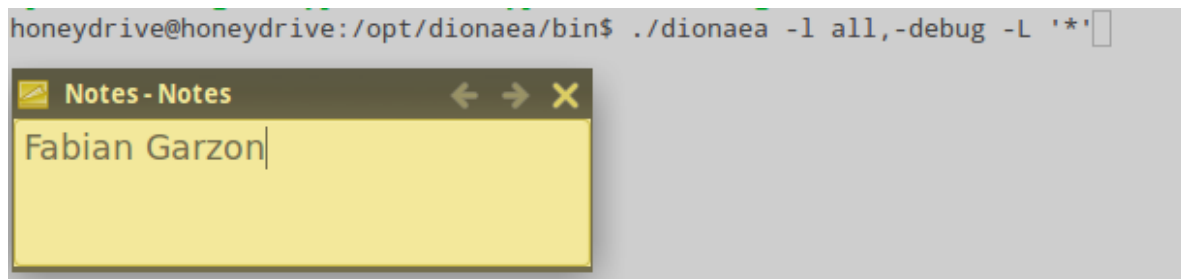


Imagen 46. Subir servicios

Al hacer esto la terminal dejará de recibir instrucciones, es importante no cerrar esta ventana para lo que se hará después.

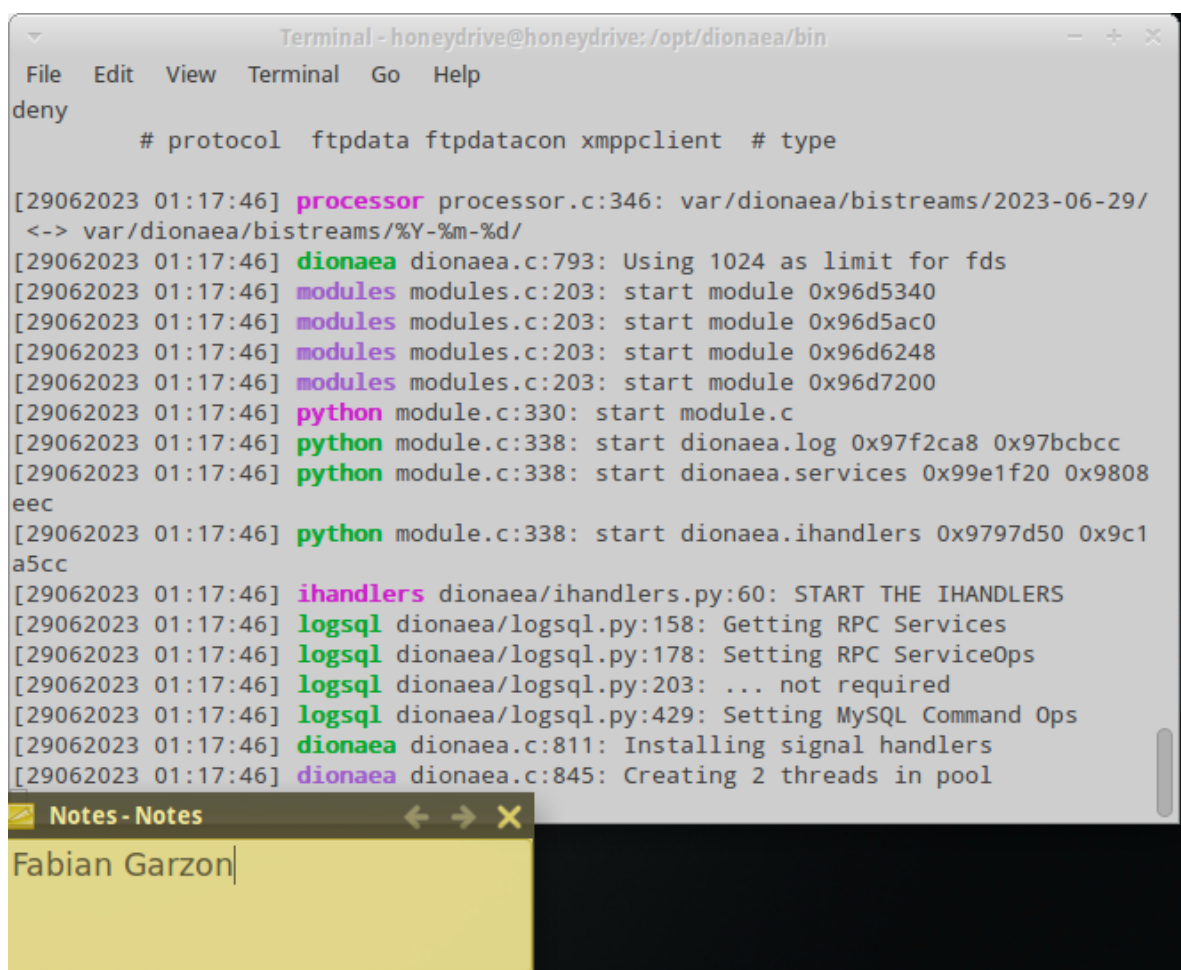


Imagen 47. Servicios subidos

Ahora en una nueva terminal dirigirse al honeydrive y al dionaeafr, ya que se usará un archivo Python para montar el servidor.

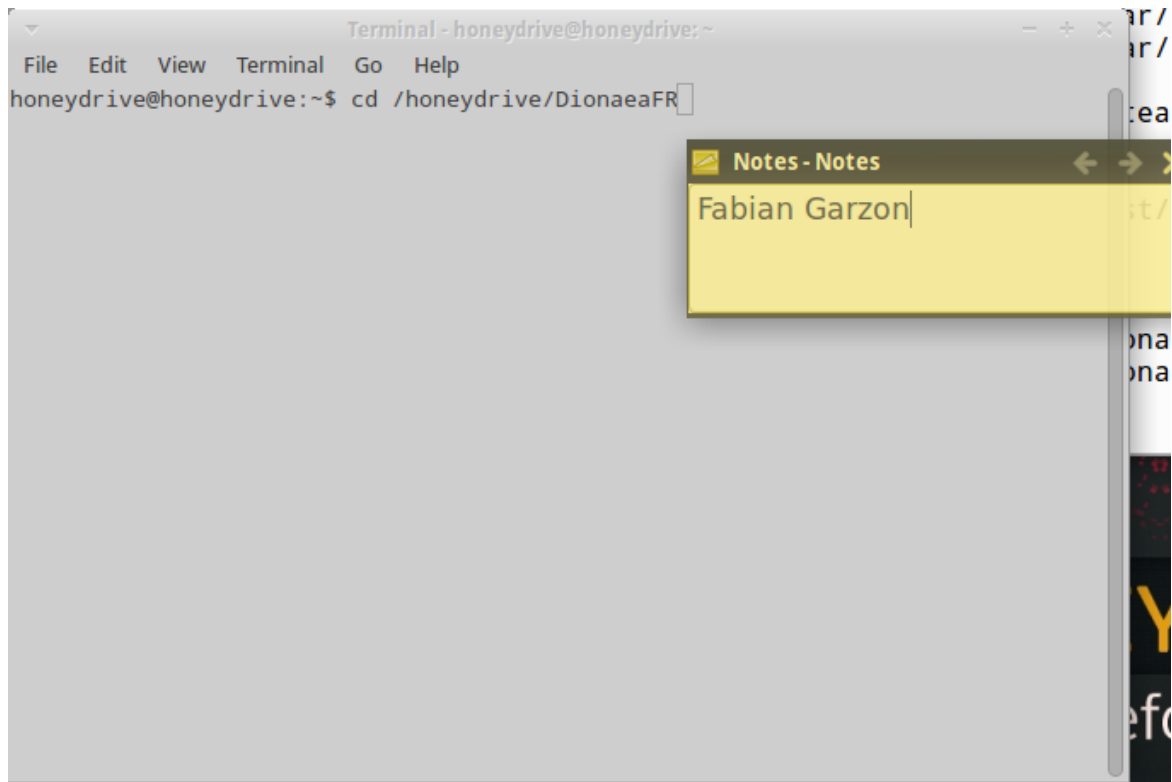


Imagen 48. Ir a dionaeafr

Hacer un listado dentro de la carpeta del dionaeafr para ver los archivos y verificar que se encuentre el “manage.py”.

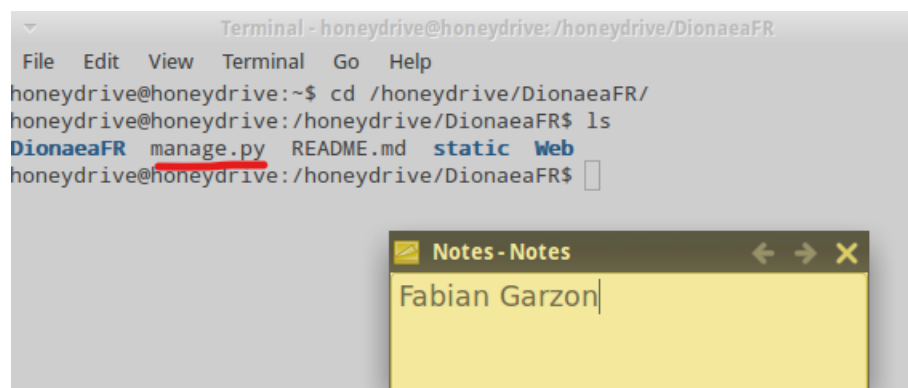


Imagen 49. Listado para ver el manage.py

Subir el servicio que se ejecutó con anterioridad al archivo Python, cuando la terminal pregunte si se desean reemplazar los archivos escribir yes y dar enter.

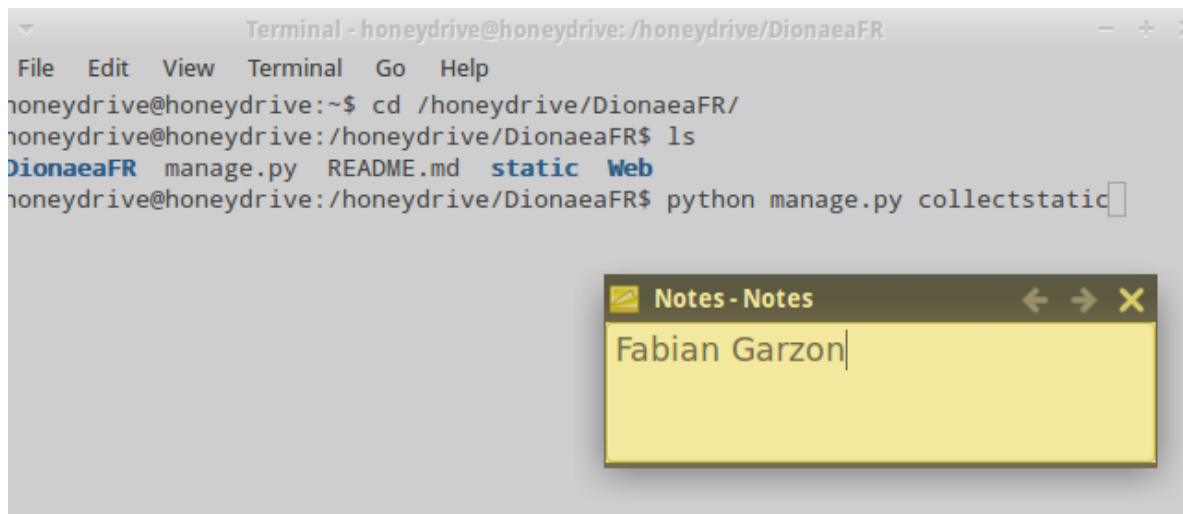


Imagen 50. Subir servicio en Python

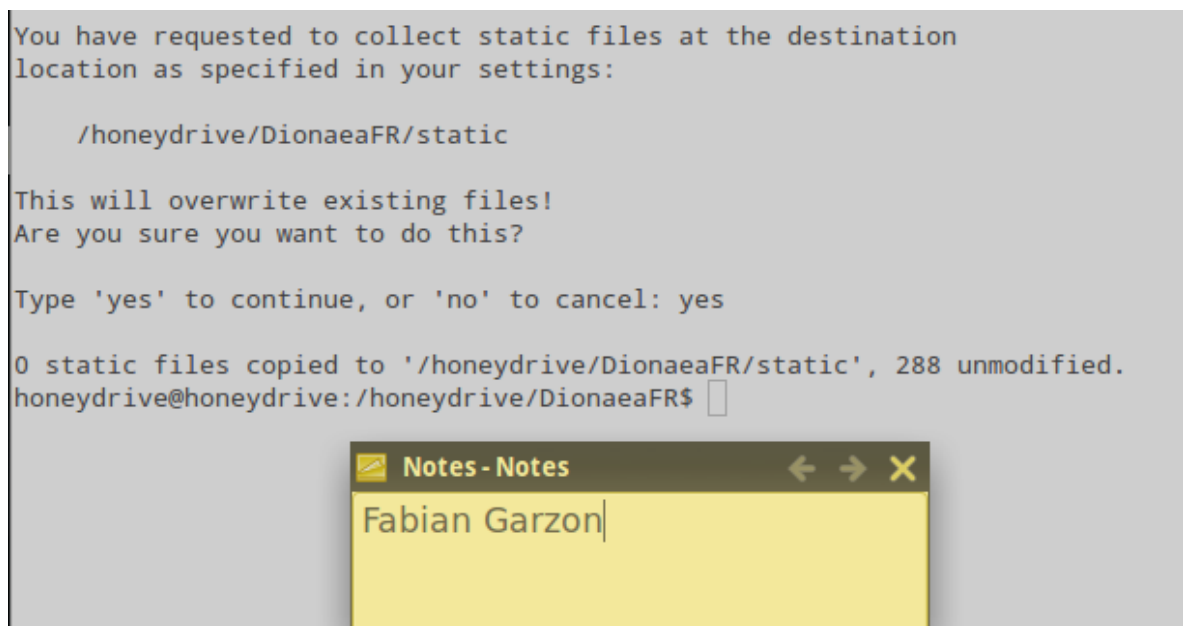
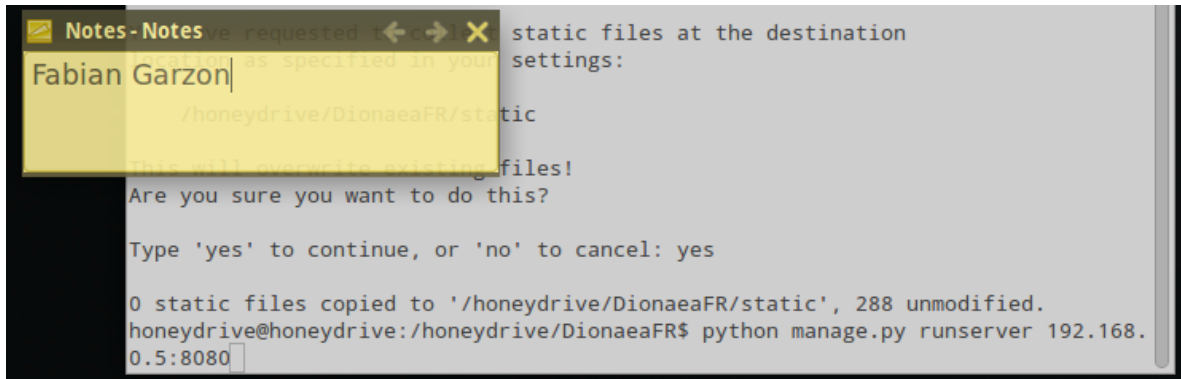


Imagen 51. Reemplazar los archivos del Python

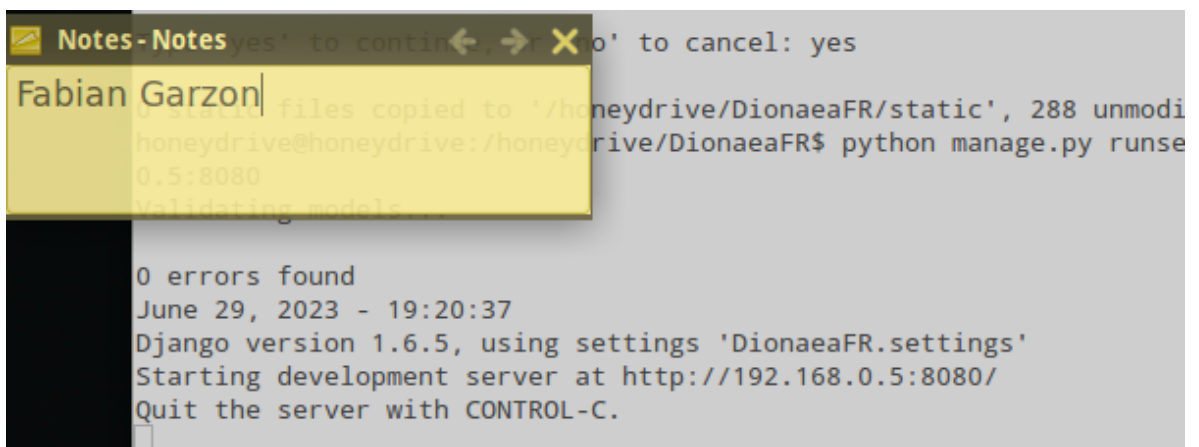
Con el siguiente comando se montará la interfaz del honeydrive a una página, para ello se usará la dirección ip del honeydrive seguida del puerto 8080.



A terminal window with a dark background. A yellow Notepad window titled "Notes - Notes" is open in the foreground, displaying the text "Fabian Garzon". The terminal text shows a command to copy static files, a confirmation prompt "Are you sure you want to do this?", and the response "yes". It then shows "0 static files copied to '/honeydrive/DionaeaFR/static', 288 unmodified." and the command "python manage.py runserver 192.168.0.5:8080".

```
static files at the destination
as specified in your settings:
/honeydrive/DionaeaFR/static
This will overwrite existing files!
Are you sure you want to do this?
Type 'yes' to continue, or 'no' to cancel: yes
0 static files copied to '/honeydrive/DionaeaFR/static', 288 unmodified.
honeydrive@honeydrive:/honeydrive/DionaeaFR$ python manage.py runserver 192.168.0.5:8080
```

Imagen 52. Subir interfaz



A terminal window with a dark background. A yellow Notepad window titled "Notes - Notes" is open in the foreground, displaying the text "Fabian Garzon". The terminal text shows the command "python manage.py runserver 192.168.0.5:8080" and the output "Validating models...". It then shows "0 errors found", the date and time "June 29, 2023 - 19:20:37", the Django version "Django version 1.6.5, using settings 'DionaeaFR.settings'", the server URL "Starting development server at http://192.168.0.5:8080/", and the instruction "Quit the server with CONTROL-C.".

```
yes' to continue, or 'no' to cancel: yes
0 static files copied to '/honeydrive/DionaeaFR/static', 288 unmodified.
honeydrive@honeydrive:/honeydrive/DionaeaFR$ python manage.py runserver 192.168.0.5:8080
Validating models...
0 errors found
June 29, 2023 - 19:20:37
Django version 1.6.5, using settings 'DionaeaFR.settings'
Starting development server at http://192.168.0.5:8080/
Quit the server with CONTROL-C.
```

Imagen 53. Interfaz subida

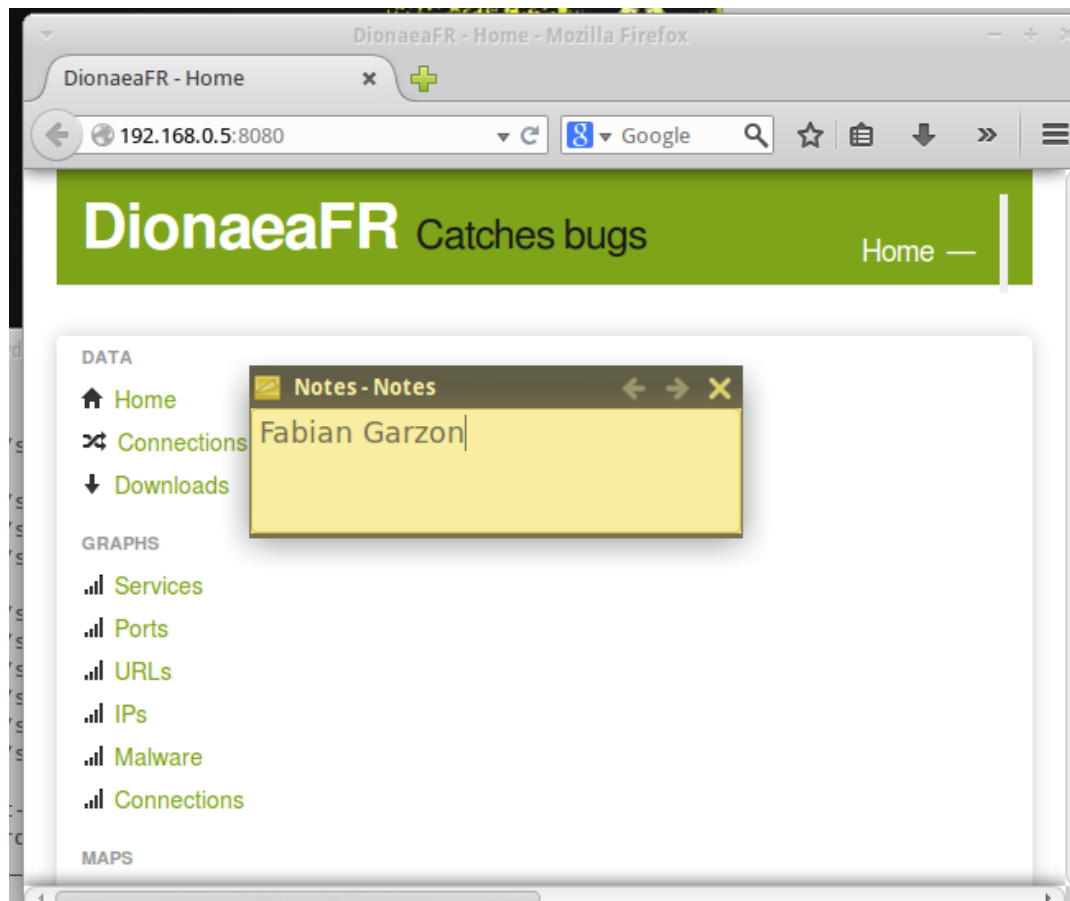


Imagen 54. Interfaz abierta en el navegador

Ahora en Kali Linux hacer un escaneo de puertos a la ip del honeydrive, al hacerlo el honeydrive detectará el ataque y hará la respectiva notificación en la interfaz.

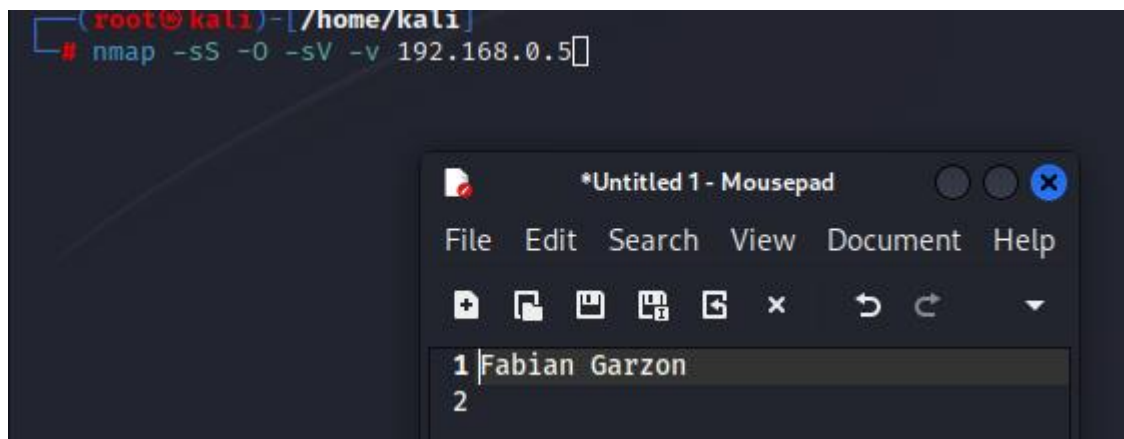


Imagen 55. Escaneo de puertos honeydrive

```
# nmap -sS -O -sV -v 192.168.0.5
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-29 15:23 EDT
NSE: Loaded 45 scripts for scanning.
Initiating ARP Ping Scan at 15:23
Scanning 192.168.0.5 [1 port]
Completed ARP Ping Scan at 15:23, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 15:23
Completed Parallel DNS resolution of 1 host. at 15:23, 0.01s elapsed
Initiating SYN Stealth Scan at 15:23
Scanning 192.168.0.5 [1000 ports]
Discovered open port 80/tcp on 192.168.0.5
Discovered open port 8080/tcp on 192.168.0.5
Discovered open port 1433/tcp on 192.168.0.5
Discovered open port 5060/tcp on 192.168.0.5
Discovered open port 5061/tcp on 192.168.0.5
Completed SYN Stealth Scan at 15:23, 0.41s elapsed (1000 total ports)
Initiating Service scan at 15:23
Scanning 5 services on 192.168.0.5
[]
```

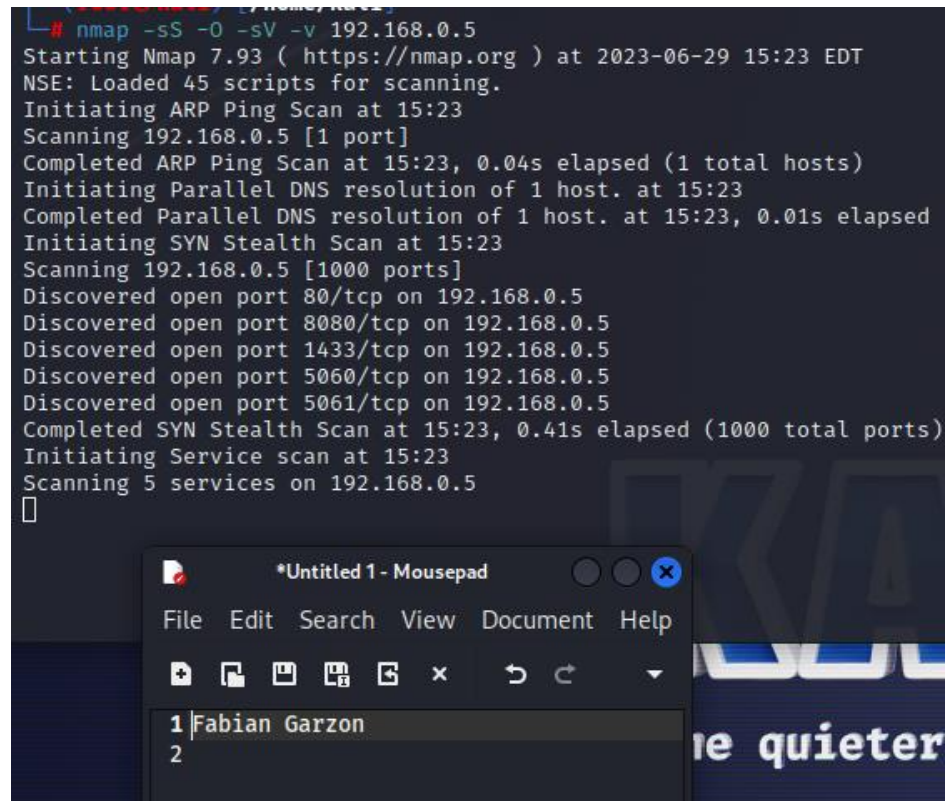


Imagen 56. Resultado escaneo de puertos

En este caso el Dionaea no capturó el ataque y por ello no se muestra un cambio en la interfaz. También se probó con red NAT y tampoco fue capturado el ataque 😞.

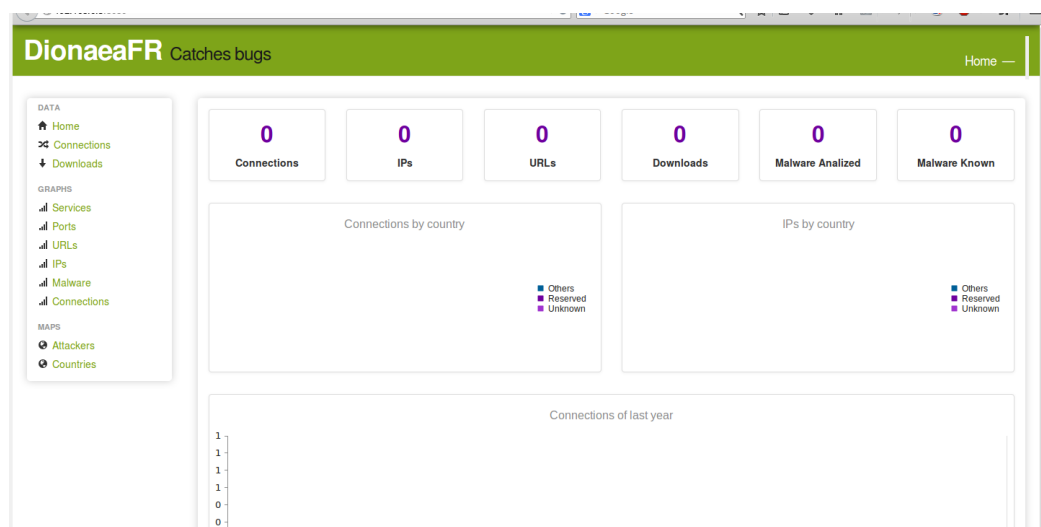


Imagen 57. Interfaz Dionaea post ataque

A10 Server side request forgery

Lab Basic SSRF against the local server

En este laboratorio se hará un ataque donde se accede como administrador a través de una URL que arroja la página en el stock de un producto. Para ello se usará Kali Linux, burpsuite y el portswigger para el laboratorio.

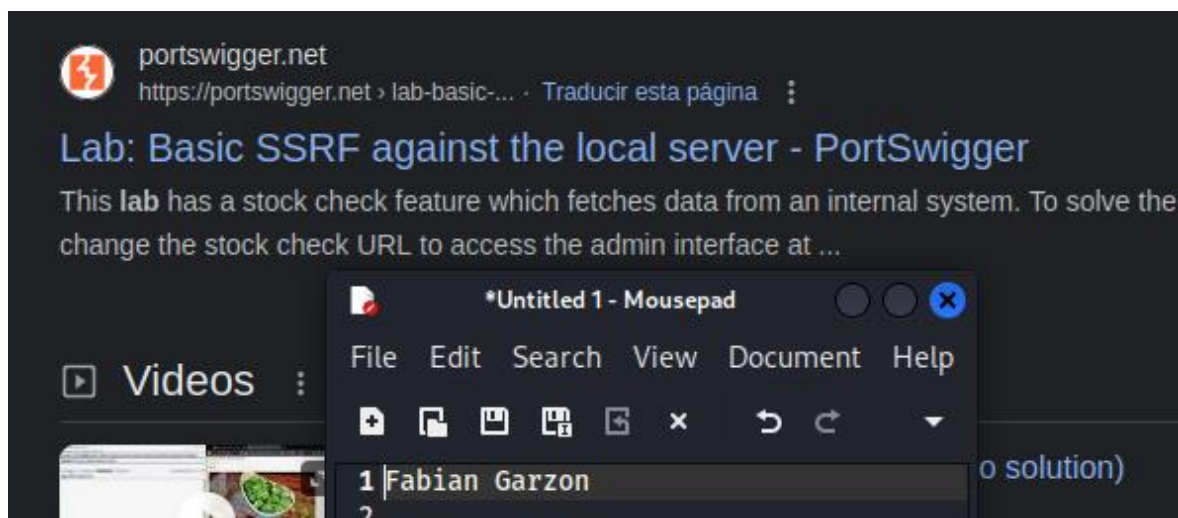


Imagen 58. Búsqueda del laboratorio

Lab: Basic SSRF against the local server

APPRENTICE



LAB

Not solved

This lab has a stock check feature which fetches data from an internal system.

To solve the lab, change the stock check URL to access the admin interface at `http://admin` and delete the user `carlos`.



ACCESS THE LAB



Solution

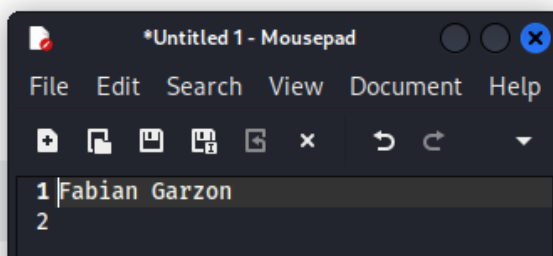


Imagen 59. Laboratorio abierto

Acceder al laboratorio y escoger alguno de los productos que estén en la página.



Description:

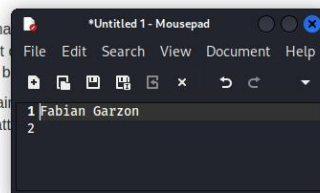
Take home your very own paintball gun and blast blue and red paint whenever you please! The Thunder Striker Paintball Gun is the perfect gift for a combat lover and anyone who believes they're a marksman. It's time to awaken your inner Rambo and channel your favourite movie characters. Whether it's just for you or you're purchasing for a birthday gift, this gun is the perfect choice. It's the ideal gift for a combat lover and anyone who believes they're a marksman. To get the best out of the Thunder Striker, be sure to purchase a pair of paintball masks. Whether it's just for you or you're purchasing for a birthday gift, this gun is the perfect choice.

It's time to awaken your inner Rambo and channel your favourite movie characters. Whether it's just for you or you're purchasing for a birthday gift, this gun is the perfect choice. It's the ideal gift for a combat lover and anyone who believes they're a marksman. To get the best out of the Thunder Striker, be sure to purchase a pair of paintball masks. Whether it's just for you or you're purchasing for a birthday gift, this gun is the perfect choice.

To get the best out of the Thunder Striker, be sure to purchase a pair of paintball masks. Whether it's just for you or you're purchasing for a birthday gift, this gun is the perfect choice. It's the ideal gift for a combat lover and anyone who believes they're a marksman. To get the best out of the Thunder Striker, be sure to purchase a pair of paintball masks. Whether it's just for you or you're purchasing for a birthday gift, this gun is the perfect choice.

London

Check stock



Whether
pellets a
n have a
flowing

Imagen 60. Producto escogido

Configurar el proxy del navegador y abrir el burpsuite en Kali Linux.

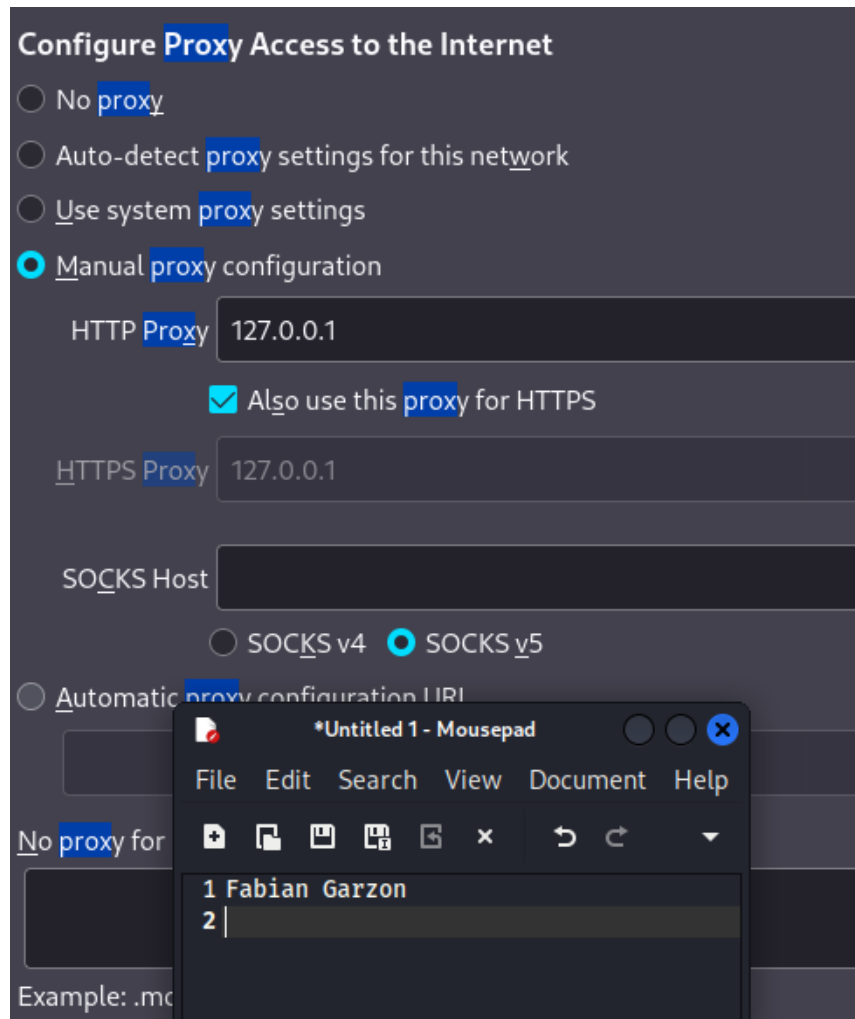


Imagen 61. Configuración proxy en el navegador

Dar clic en Check stock, al hacer esto el burpsuite capturar  por medio del proxy y los http los request que se hagan a la p gina.

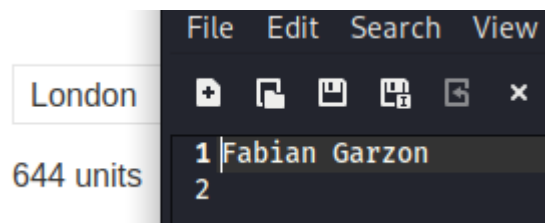


Imagen 62. Check stock

En el burpsuite en la pestaña de proxy y http, buscar el request del stock, para ello se busca un POST seguido de un /producto/stock.

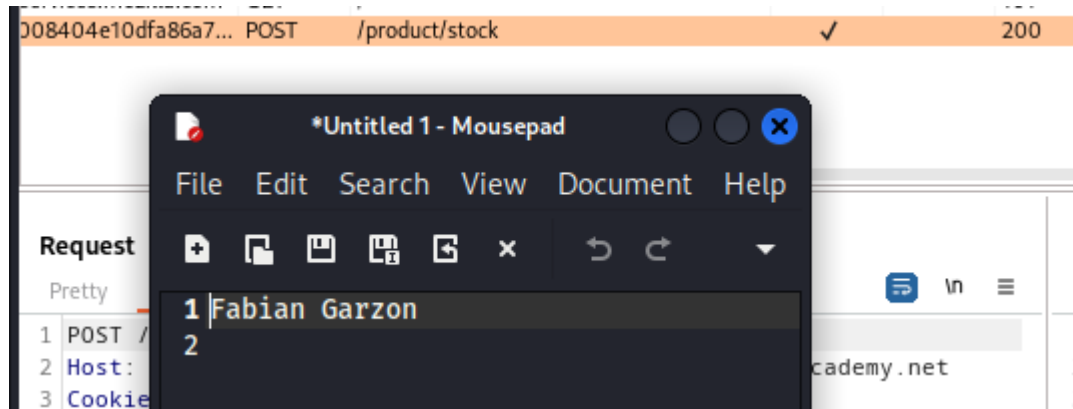


Imagen 63. Request capturado por burpsuite

Enviar el request al repeater con Control + R o dar clic derecho y enviar a repeater.

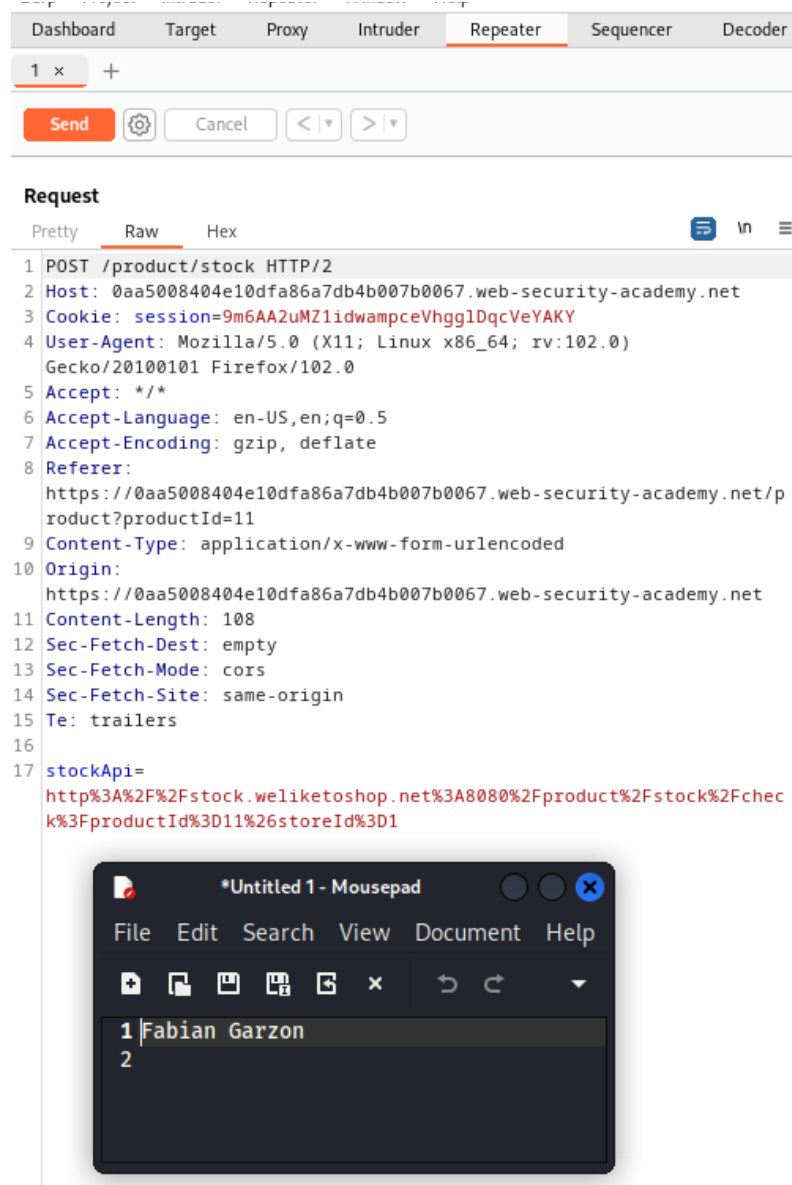


Imagen 64. Request enviado a repeater

Copiar el texto que aparece en stockApi e ir a Decoder y pegar ahí el texto.

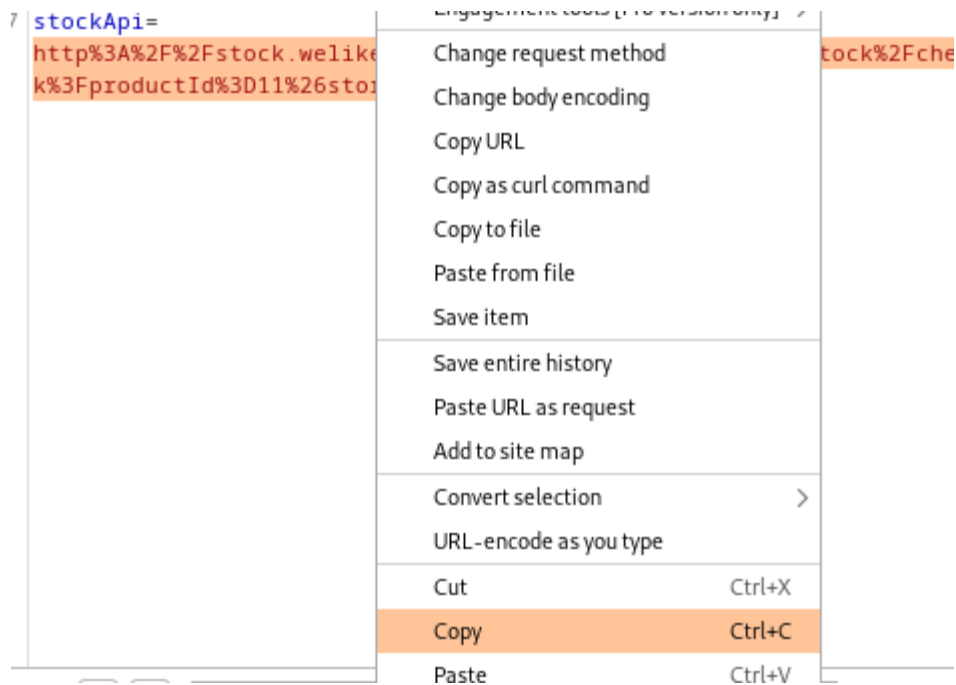


Imagen 65. StockApi copiado

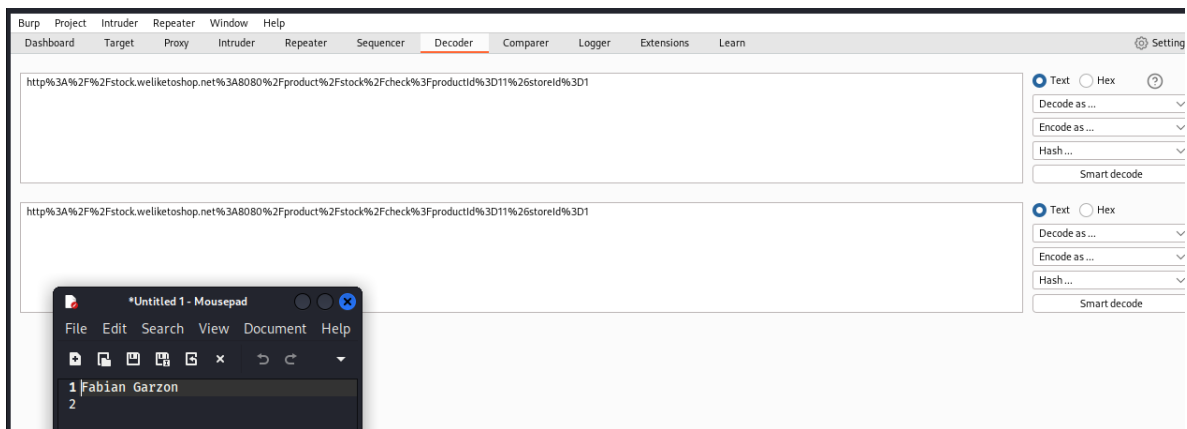


Imagen 66. StockApi pegado en Decoder

Ahora decodificar ese stockApi como URL.

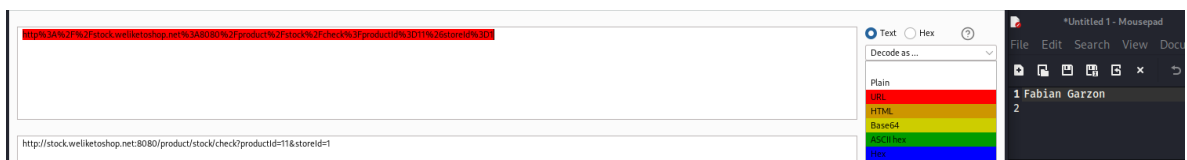


Imagen 67. StockApi decodificado

Teniendo esto, volver al repeater y cambiar el stockApi por la URL localhost y admin, y dar clic el send.

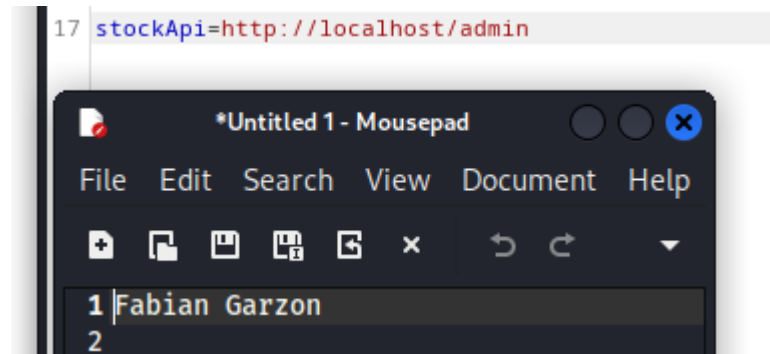


Imagen 68. Cambio stockApi

Al dar clic en send, buscar en el response en el apartado de Admin el comando para eliminar el usuario Carlos.

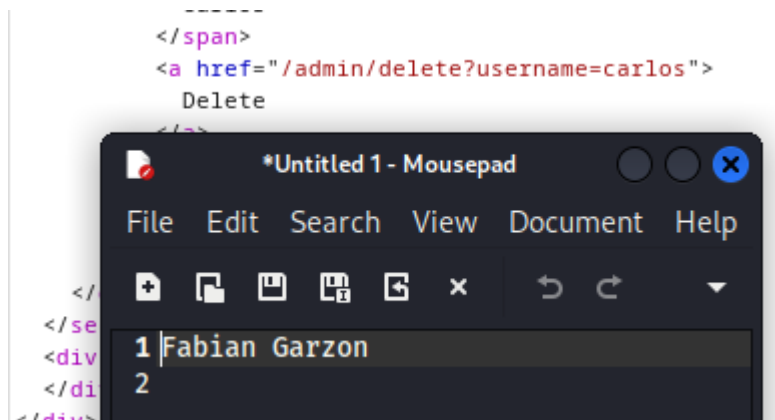


Imagen 69. Comando para eliminar a Carlos

Insertar ese código en el request y dar clic en send.

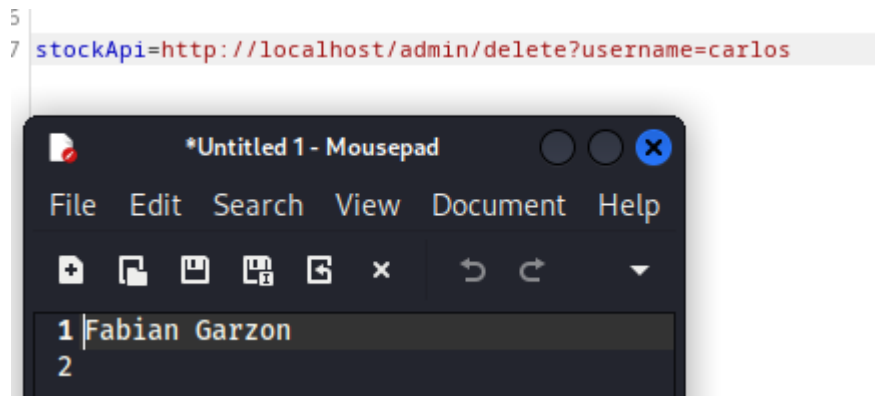


Imagen 70. URL con el comando para eliminar a Carlos

Por último, dar clic en follow redirection, esto cambiará el request que estaba en un principio.

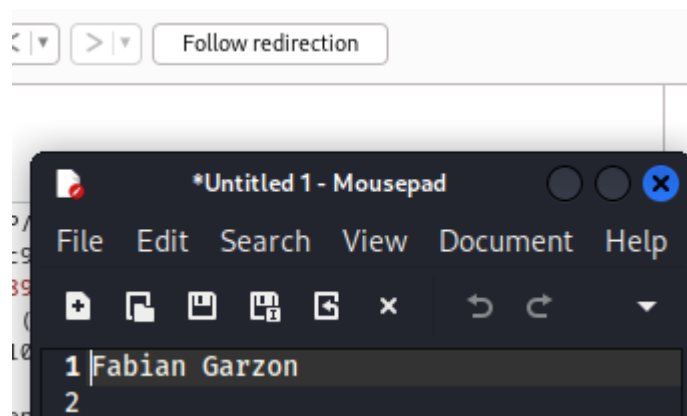


Imagen 71. Clic en follow redirection

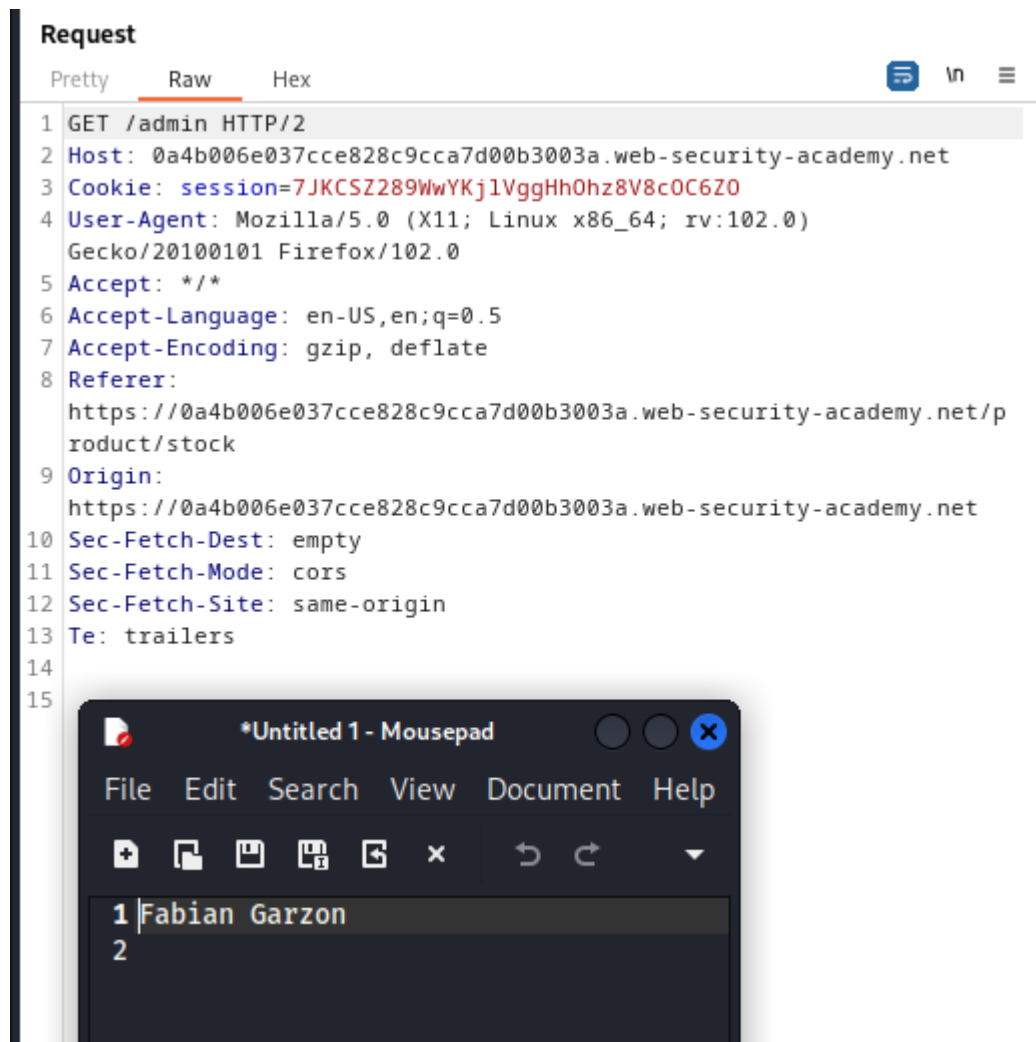


Imagen 72. Cambio del request

Congratulations, you solved the lab!

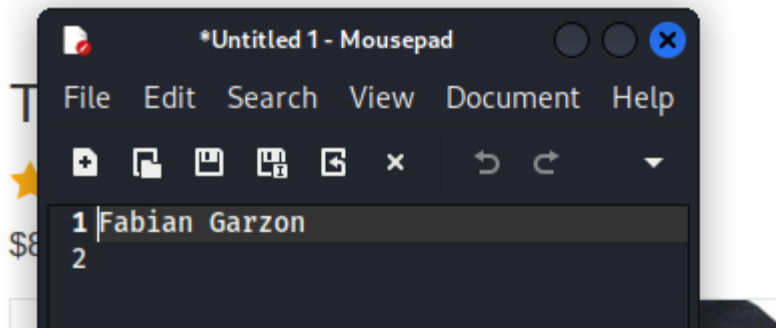


Imagen 73. Laboratorio solucionado

Conclusiones

- Acceder siempre a páginas que cuenten con todos los certificados y demás protocolos de seguridad para evitar robo de datos.
- Configurar de una buena forma un firewall para que los atacantes no tengan posibilidades de obtener información.
- No ingresar datos en páginas que no cuenten con protocolos de seguridad, ya que se corre el riesgo de que la página sea atacada y estarían en peligro los datos que se registraron.